UNIVERSIDAD MAYOR DE SAN ANDRES FACULTAD DE CIENCIAS PURAS Y NATURALES CARRERA DE INFORMATICA



TRABAJO DE INVESTIGACIÓN

CIBERATAQUES

Asignatura: Seguridad de la Información

Sigla: SEG - 244

Docente: Ph. D. Luisa Velásquez López

Integrantes: Bustillos Choque Miguel Angel

Colque Paucara Klever Calet

Mamani Colmena Gerson (Representante)

Rojas Guachalla Ranulfo Antonio

01 de septiembre – 2026

La Paz – Bolivia

ÍNDICE

1. Cross-Site Request Forgery (CSRF) **6**
Nombre 6
Por quién fue creado 6
Cuál es el objetivo 6
Descripción 6
Por qué medio se produce (con ejemplos reales) 6
Cuál es el porcentaje de envíos por día 6
Qué procesos de ataque realiza (fases técnicas) 6
2. Ingeniería Social **9**
Nombre 9
Por quién fue creado 9
Cuál es el objetivo 9
Descripción 9
Por qué medio se produce (con ejemplos reales) 9
Cuál es el porcentaje de envíos por día 9
Qué procesos de ataque realiza (fases técnicas) 9
3. Keylogging **12**
Nombre 12
Por quién fue creado 12
Cuál es el objetivo 12
Descripción 12
Por qué medio se produce (con ejemplos reales) 12
Cuál es el porcentaje de envíos por día 12
Qué procesos de ataque realiza (fases técnicas) 12
4. Escalada de privilegios **15**
Nombre 15
Por quién fue creado 15
Cuál es el objetivo 16
Descripción 16
Por qué medio se produce (con ejemplos reales) 16
Cuál es el porcentaje de envíos por día 16
Qué procesos de ataque realiza (fases técnicas) 16
5. Ataque a la cadena de suministro (Supply Chain Attack) — versión I **19**
Nombre 19
Por quién fue creado 19
Cuál es el objetivo 20
Descripción 20
Por qué medio se produce (con ejemplos reales) 20
Cuál es el porcentaje de envíos por día 20
Qué procesos de ataque realiza (fases técnicas) 20
6. Ransomware **23**
Nombre 23

Por quién fue creado....23
Cuál es el objetivo....24
Descripción....24
Por qué medio se produce (con ejemplos reales)....24
Cuál es el porcentaje de envíos por día....24
Qué procesos de ataque realiza....24
7. Ataque de fuerza bruta....25
Nombre....25
Por quién fue creado....26
Cuál es el objetivo....26
Descripción....26
Por qué medio se produce (con ejemplos reales)....26
Cuál es el porcentaje de envíos por día....26
Qué procesos de ataque realiza....26
8. SQL Injection....27
Nombre....27
Por quién fue creado....27
Cuál es el objetivo....27
Descripción....27
Por qué medio se produce (con ejemplos reales)....27
Cuál es el porcentaje de envíos por día....28
Qué procesos de ataque realiza....28
9. Ataque de día cero....29
Nombre....29
Por quién fue creado....29
Cuál es el objetivo....29
Descripción....29
Por qué medio se produce (con ejemplos reales)....29
Cuál es el porcentaje de envíos por día....30
Qué procesos de ataque realiza....30
10. Ataque de diccionario....30
Nombre....30
Por quién fue creado....31
Cuál es el objetivo....31
Descripción....31
Por qué medio se produce (con ejemplos reales)....31
Cuál es el porcentaje de envíos por día....31
Qué procesos de ataque realiza....32
11. Ataque a la cadena de suministro (Supply Chain Attack) — versión II....34
Nombre....34
Por quién fue creado....34
Cuál es el objetivo....34
Descripción....35
Por qué medio se produce (con ejemplos)....35

Cuál es el porcentaje de envíos por día....35
Qué procesos de ataque realiza....36
12. Man-in-the-Middle (MITM)....36
Nombre....36
Por quién fue creado....36
Cuál es el objetivo....36
Descripción....37
Por qué medio se produce (con ejemplos)....37
Cuál es el porcentaje de envíos por día....37
Qué procesos de ataque realiza....38
13. XSS (Cross-Site Scripting)....38
Nombre....38
Por quién fue creado....38
Cuál es el objetivo....39
Descripción....39
Por qué medio se produce (con ejemplos)....39
Cuál es el porcentaje de envíos por día....39
Qué procesos de ataque realiza....40
14. Spoofing....40
Nombre....20
Por quién fue creado....20
Cuál es el objetivo....20
Descripción....20
Por qué medio se produce (con ejemplos)....20
Cuál es el porcentaje de envíos por día....20
Qué procesos de ataque realiza....20
15. Drive-by Download....42
Nombre....42
Por quién fue creado....42
Cuál es el objetivo....42
Descripción....42
Por qué medio se produce (con ejemplos)....43
Cuál es el porcentaje de envíos por día....43
Qué procesos de ataque realiza....43
16. Phishing....44
Quién creó el phishing....44
Cuál es su objetivo....44
Descripción....44
Por qué medios se produce....45
Cuál es el porcentaje de envíos por día....45
Qué procesos de ataque realiza....46
17. Spear phishing....46
Quién creó el spear phishing....46
Cuál es su objetivo....46

Descripción....46
Por qué medios se produce....47
Cuál es el porcentaje de envíos por día....47
Qué procesos de ataque realiza....47
18. DoS (Denegación de Servicio)....48
Descripción / origen....48
Cuál es su objetivo....48
Descripción....48
Por qué medios se produce....49
Cuál es el porcentaje de envíos por día....49
Qué procesos de ataque realiza....49
19. DDoS (Denegación de Servicio Distribuido)....50
Quién creó el DDoS....50
Cuál es su objetivo....50
Descripción....50
Por qué medios se produce....51
Cuál es el porcentaje de envíos por día....51
Qué procesos de ataque realiza....52
20. ¿Qué países tienen más ataques de ransomware?....52
21. ¿Cuáles son sus pérdidas?....52

Cross-Site Request Forgery (CSRF)

Cross-Site Request Forgery (CSRF), también conocida por las siglas alternativas XSRF, y por los nombres coloquiales "Sea Surf" (por la pronunciación de CSRF), "one-click attack" o "session riding" es un tipo de exploit malicioso de un sitio web o aplicación web en el que se envían comandos no autorizados desde un usuario en quien la aplicación web confía.

Por quién fue creado

CSRF no fue "inventado" por una sola persona como una herramienta, sino que es una clase de vulnerabilidad identificada progresivamente por la comunidad de seguridad informática:

- El concepto raíz —el problema de "confused deputy" (diputado confundido) a nivel de aplicación, donde un programa con privilegios es engañado para usar mal su autoridad— fue descrito por Norm Hardy en 1988, mucho antes de que existiera el término CSRF En 1988 Norm Hardy publicó un documento explicando un problema de confianza a nivel de aplicación al que llamó "confused deputy".
- En el año 2000, una publicación en la lista de correo bugtraq explicó cómo el software ZOPE se veía afectado por un problema de "confused deputy" que hoy definiríamos como una vulnerabilidad CSRF.
- El nombre "CSRF" fue acuñado formalmente por Peter Watkins, quien nombró a estas vulnerabilidades como CSRF o XSRF en una publicación de junio de 2001 en la lista de correo Bugtraq, en respuesta a un hilo titulado "The Dangers of Allowing Users to Post Images" .
- El término se popularizó recién después de 2004, y su difusión masiva se atribuye principalmente a los investigadores Chris Shiflett (de OmniTI) y Jeremiah Grossman (de WhiteHat Security) quienes descubrieron y divulgaron ampliamente los ataques CSRF.

Cuál es el objetivo

El objetivo de CSRF es forzar a un usuario final a ejecutar acciones no deseadas en una aplicación web en la que se encuentra actualmente autenticado. A diferencia de otros ataques, el atacante no necesita robar la sesión del usuario: aprovecha que, mientras el usuario esté autenticado y su navegador envíe una solicitud HTTP con sentido a la aplicación, esta no puede distinguir si el origen de la solicitud es una transacción legítima o un enlace en el que la víctima hizo clic sin saberlo. Si la víctima es un usuario común, el ataque puede forzar la ejecución de solicitudes que cambian el estado del sistema, como transferencias de fondos o cambios de correo electrónico; si la víctima es una cuenta administrativa, CSRF puede comprometer toda la aplicación web.

Descripción

CSRF explota la confianza entre el navegador de un usuario y una aplicación en la que ya está autenticado, engañando al navegador para que envíe una solicitud no deseada. Es importante distinguirlo de XSS: mientras que el Cross-Site Scripting explota la confianza que un usuario tiene en un sitio determinado, CSRF explota la confianza que un sitio tiene en el navegador del usuario. El atacante nunca ve la respuesta de la solicitud forjada —por eso CSRF se usa típicamente para cambiar el estado del sistema (transferencias, cambios de contraseña, etc.) y no para robar datos directamente, salvo en variantes específicas—.

Un rasgo forense importante: CSRF no se puede rastrear fácilmente porque el ataque se ejecuta desde la dirección IP del propio usuario legítimo, lo que dificulta enormemente su detección en investigaciones posteriores.

Por qué medio se produce (con ejemplos reales)

Un ataque CSRF puede propagarse por cualquier medio capaz de hacer que el navegador de la víctima envíe una solicitud sin su conocimiento: un sitio web malicioso, un correo electrónico, un blog, un mensaje instantáneo o un programa pueden engañar al navegador web de un usuario autenticado para que realice una acción no deseada en un sitio de confianza. Técnicamente, esto se logra mediante etiquetas de imagen especialmente diseñadas, formularios ocultos y peticiones JavaScript fetch o XMLHttpRequest, que pueden funcionar sin interacción o incluso sin conocimiento del usuario.

Casos reales documentados:

- Gmail (2007): un investigador de Internet Security Auditors descubrió que la función de "cambiar contraseña" de Gmail era vulnerable a CSRF porque el único token de autenticación necesario era una cookie de sesión enviada automáticamente por el navegador, permitiendo a un atacante cambiar la contraseña de la víctima o robar su lista de contactos .
- Netflix (2006): el sitio de Netflix tenía numerosas vulnerabilidades CSRF que podían permitir a un atacante agregar un DVD a la cola de alquiler de la víctima, cambiar la dirección de envío de la cuenta, o incluso alterar las credenciales de inicio de sesión para comprometer totalmente la cuenta.
- YouTube (2008): YouTube también fue vulnerable a CSRF, lo que permitía a cualquier atacante realizar casi todas las acciones de cualquier usuario.
- ING Direct (2008): la aplicación de banca en línea de ING Direct era vulnerable a un ataque CSRF que permitía transferencias de dinero ilícitas.
- µTorrent (CVE-2008-6586): una vulnerabilidad CSRF real en µTorrent explotaba el hecho de que su consola web accesible en localhost:8080 permitía ejecutar acciones críticas mediante una simple solicitud GET, como forzar la descarga de un archivo .torrent malicioso o cambiar la

contraseña de administrador; los ataques se lanzaban colocando elementos HTML de imagen de acción automática en foros y correo spam.

- TikTok (2020): ByteDance recibió reportes de una vulnerabilidad que permitía a atacantes enviar mensajes con malware a usuarios de TikTok, quienes tras la infección podían sufrir ataques CSRF o XSS que hacían que otras cuentas enviaran solicitudes en su nombre; el fallo fue corregido en tres semanas.

Cuál es el porcentaje de envíos por día (o de incidencia/frecuencia)

No existe una fuente confiable que reporte un "porcentaje de envíos por día" para CSRF (a diferencia de, por ejemplo, el phishing por correo, que sí suele medirse en volumen diario de envíos). CSRF es una vulnerabilidad de aplicación web, no una campaña de distribución masiva, por lo que las fuentes especializadas la miden en términos de incidencia/prevalencia, no de volumen diario. Los datos verificables más cercanos disponibles son:

- Según el informe de vulnerabilidades de Intel 471 correspondiente a 2023, CSRF apareció por primera vez entre los cinco tipos de vulnerabilidad más comunes reportados, con 1,324 ocurrencias registradas, detrás de XSS (5,297), inyección SQL (2,261) y out-of-bounds write (2,066).
- Un estudio académico que evaluó 500 sitios web encontró que el 75% de las aplicaciones analizadas eran vulnerables a CSRF, frente a un 65% vulnerable a XSS (fuente: estudio citado en ResearchGate sobre seguridad de sitios gubernamentales y financieros de Bangladesh).
- Es relevante mencionar que CSRF llegó a ocupar el 5.° lugar en el OWASP Top 10 de 2007 pero fue retirada del marco de referencia OWASP en 2017 debido a su baja tasa de incidencia relativa gracias a la adopción de defensas integradas en frameworks modernos, aunque volvió a generar atención con casos de alto perfil en 2018.

Qué procesos de ataque realiza (fases técnicas)

1. Reconocimiento del objetivo: el atacante identifica una acción "significativa" dentro de la aplicación —como cambiar una contraseña o transferir dinero— que pueda ejecutarse mediante una solicitud HTTP predecible.
2. Verificación de ausencia de protección: el atacante comprueba que la aplicación no valida adecuadamente el origen de la solicitud (ausencia de token anti-CSRF, o de verificación de cabeceras Origin/Referer) , ya que asegurar que la solicitud HTTP proviene del sitio original es lo que impide que funcionen los ataques desde otros sitios.
3. Construcción de la solicitud forjada: se crea el vector malicioso —una etiqueta <img>, un formulario oculto autoenviado, o código JavaScript— que replica exactamente la solicitud legítima que la aplicación espera.

4. Distribución mediante ingeniería social: con ayuda de ingeniería social, como el envío de un enlace por correo o chat, el atacante induce a la víctima a visitar la página que contiene el vector.
5. Ejecución involuntaria por parte de la víctima: la víctima navega, sin saberlo, a un documento web bajo control del adversario; sin su conocimiento ni consentimiento, ese documento genera una solicitud HTTP de origen cruzado.
6. Envío automático de credenciales de sesión: el navegador de la víctima adjunta automáticamente las cookies de sesión válidas a la solicitud forjada, ya que la aplicación no tiene forma de saber si el origen de la solicitud es una transacción válida o un enlace en el que se hizo clic mientras el usuario estaba autenticado.
7. Procesamiento no autorizado en el servidor: la solicitud provoca una operación permanente de cambio de estado en el sistema atacado, atribuida a la víctima, completando el ataque sin que el usuario lo perciba.

Ingeniería Social

Nombre

Ingeniería social (Social Engineering). En seguridad informática también se le conoce como "hacking humano" o "manipulación psicológica aplicada a la seguridad de la información", ya que agrupa un conjunto de técnicas (no una técnica única) orientadas a explotar el factor humano en lugar de una falla técnica.

Por quién fue creado

La ingeniería social como técnica de intrusión no tiene un único "creador", pero su popularización en el ámbito de la ciberseguridad está históricamente asociada a Kevin Mitnick, quien ayudó a popularizar el concepto de "ingeniería social" en el mundo de la ciberseguridad durante los años noventa, entendida como la práctica de diseñar situaciones sociales para engañar a una persona y hacer que realice una acción.

Mitnick comenzó a desarrollar estas técnicas desde joven —a los 12 años ya manipulaba a un conductor de autobús de Los Ángeles para obtener información que le permitiera viajar gratis— y las perfeccionó a lo largo de los años 80 y 90, combinando pretextos (pretexting), phishing y suplantación (spoofing) para obtener acceso a sistemas y redes protegidas. Fue arrestado por el FBI el 15 de febrero de 1995 y pasó varios años en prisión; tras su liberación se convirtió en consultor de seguridad y autor de libros como El arte del engaño, en los que sistematizó y enseñó públicamente estas técnicas, por lo

que se le suele llamar informalmente "el padre de la ingeniería social" en el ámbito de la ciberseguridad moderna. Mitnick falleció el 16 de julio de 2023.

Es importante aclarar —y así se documentará en el trabajo— que la ingeniería social como fenómeno de manipulación humana es mucho más antigua que la informática (estafas, engaños y pretextos han existido siempre); lo que Mitnick y otros hackers de su generación hicieron fue aplicarla sistemáticamente a la intrusión de sistemas informáticos.

Cuál es el objetivo

El objetivo de la ingeniería social es manipular psicológicamente a una persona para que, de forma voluntaria y sin darse cuenta de que está siendo engañada, realice una acción que compromete la seguridad de un sistema, una organización o su propia información: revelar una contraseña, otorgar acceso físico o digital, transferir dinero, instalar software malicioso o divulgar datos confidenciales. A diferencia de un ataque puramente técnico, la ingeniería social no explota una vulnerabilidad de software, sino sesgos cognitivos humanos como la confianza, la urgencia, el miedo, la autoridad o la reciprocidad.

Descripción

La ingeniería social consiste en manipular a las personas mediante engaños para que, voluntariamente, hagan algo que no deberían hacer, aprovechando que el eslabón más débil de cualquier sistema de seguridad no es la tecnología, sino el factor humano. Los datos de la industria respaldan esta afirmación de forma contundente: según el Verizon Data Breach Investigations Report (DBIR) 2024, el 68% de las brechas de seguridad analizadas involucraron un elemento humano no malicioso, como una persona siendo víctima de un ataque de ingeniería social o cometiendo un error. El DBIR 2025 mantiene esta tendencia, con un 60% de las brechas involucrando el elemento humano.

Puede combinarse con técnicas puramente técnicas (como CSRF o malware) como parte de una cadena de ataque más amplia, pero su núcleo distintivo es siempre la manipulación psicológica del objetivo humano.

Por qué medio se produce (con ejemplos reales)

La ingeniería social se manifiesta mediante múltiples vectores: llamadas telefónicas (vishing), correo electrónico (phishing), mensajería y redes sociales, suplantación de identidad presencial (pretexting), USBs infectados dejados intencionalmente, e incluso mensajes de texto (smishing).

Caso real — Twitter, julio de 2020: el 15 de julio de 2020, entre las 20:00 y 22:00 UTC, aproximadamente 130 cuentas de alto perfil de Twitter (incluyendo Barack Obama, Elon Musk, Bill Gates y Apple) fueron comprometidas mediante un ataque coordinado de ingeniería social contra empleados de Twitter, quienes fueron manipulados para otorgar acceso a herramientas administrativas internas. El vector específico fue una combinación de vishing (llamadas telefónicas) y spear-phishing:

los atacantes llamaron a múltiples empleados de Twitter haciéndose pasar por el departamento de soporte de TI, alegando un problema con la VPN interna de la empresa, y dirigieron a los empleados a un sitio de phishing idéntico al portal de inicio de sesión de la VPN real de Twitter. Con las credenciales obtenidas, accedieron a herramientas de soporte de cuentas y publicaron mensajes promoviendo una estafa de bitcoin, recaudando más de 110,000 dólares en criptomonedas en minutos. El Departamento de Justicia de EE.UU. señaló que el ataque combinó brechas técnicas con ingeniería social.

Otros ejemplos documentados de la técnica: el propio Kevin Mitnick relataba cómo obtuvo un número de solicitante para infiltrarse en el Departamento de Vehículos Motorizados (DMV) de California simplemente llamando y haciéndose pasar por personal autorizado, sin usar ninguna herramienta técnica.

Cuál es el porcentaje de envíos por día (o de incidencia/frecuencia)

No existe una fuente confiable con un dato exacto de "envíos por día" para ingeniería social en general (a diferencia del phishing por correo, que sí se mide a veces en volumen), porque la ingeniería social es una categoría amplia de técnicas y no una campaña masiva de un solo tipo de mensaje. Los datos verificables más cercanos, medidos como prevalencia en brechas de seguridad confirmadas, son:

- DBIR 2024 (Verizon): el 68% de las brechas analizadas involucraron un elemento humano no malicioso (ingeniería social o error). Dentro de los incidentes de ingeniería social específicamente, se registraron 3,661 incidentes con 3,032 casos confirmados de exposición de datos, con motivación financiera en el 95% de los casos. El phishing y el pretexting por correo representaron el 73% de los incidentes de la categoría de ingeniería social.
- DBIR 2025 (Verizon): el elemento humano estuvo presente en el 60% de las brechas; de 4,009 incidentes de ingeniería social analizados, el 85% resultó en exposición confirmada de datos, y el phishing fue el método usado en el 57% de esos casos.
- DBIR 2020 (Verizon), citado en el análisis del caso Twitter: de 3,950 brechas de datos analizadas ese año, más del 22% se debieron a "ataques sociales".

Qué procesos de ataque realiza (fases técnicas)

1. Reconocimiento (Footprinting/OSINT): el atacante recopila información pública sobre la organización o la víctima —en el caso de Twitter, los atacantes extrajeron datos de empleados desde LinkedIn para identificar quiénes tenían privilegios administrativos sobre las herramientas internas.
2. Selección del pretexto: se diseña una historia o identidad falsa creíble (ej. "soporte técnico de TI", "proveedor externo", "nuevo empleado") que justifique el contacto y la solicitud posterior.

3. Establecimiento de contacto y generación de confianza: el atacante contacta a la víctima por el canal elegido (llamada, correo, mensaje) y utiliza principios psicológicos —autoridad, urgencia, familiaridad— para reducir la sospecha del objetivo.
4. Explotación / solicitud de la acción: se induce a la víctima a realizar la acción deseada: revelar una contraseña, hacer clic en un enlace, introducir credenciales en un sitio falso o transferir fondos. En el caso de Twitter, esto implicó dirigir a los empleados a una página de login falsa e idéntica a la VPN real.
5. Escalamiento mediante información obtenida: la información conseguida en una interacción se usa para dar credibilidad a la siguiente, permitiendo escalar de empleados con bajo acceso a empleados con privilegios administrativos.
6. Ejecución del objetivo final: con el acceso obtenido, el atacante ejecuta la acción maliciosa central (robo de datos, fraude financiero, publicación de contenido no autorizado, etc.).
7. Borrado de rastros / salida: el atacante intenta minimizar evidencia de la manipulación social empleada, dificultando la atribución, ya que a diferencia de un exploit técnico, no suele dejar artefactos de malware que un antivirus pueda detectar.

Keylogging

Nombre

Keylogging (registro de pulsaciones de teclado), también llamado keystroke logging. Las herramientas que lo ejecutan se llaman keyloggers o registradores de pulsaciones, y pueden ser de tipo hardware o software.

Por quién fue creado

El keylogging tiene dos orígenes paralelos bien documentados, uno de hardware y otro de software:

- Origen en espionaje estatal (hardware, años 70): los primeros keyloggers conocidos fueron creados por la inteligencia de la Unión Soviética (presumiblemente el KGB) para instalarse en máquinas de escribir eléctricas IBM Selectric utilizadas por entidades del gobierno de EE. UU. en Moscú y Leningrado. Conocido como el "Selectric bug", el dispositivo medía los campos magnéticos generados por el cabezal de impresión y transmitía la información de las pulsaciones por radio a los espías soviéticos; no fue detectado por un aliado estadounidense sino hasta 1984, cuando se hallaron micrófonos de este tipo en dieciséis máquinas de escribir.
- Origen en software (1983): el primer keylogger basado en software fue desarrollado por Perry Kivolowitz, entonces estudiante de posgrado en Stony Brook, quien publicó el código en los grupos de noticias de Usenet net.unix-wizards y net.sources el 17 de noviembre de 1983 como prueba de concepto; el programa localizaba y volcaba las listas de caracteres (clists) mientras

eran ensambladas en el kernel de Unix. Esta publicación fue un factor motivador para restringir el acceso a /dev/kmem en sistemas Unix.

Durante los años 90, con la expansión de Internet, los keyloggers de software se diversificaron y comenzaron a distribuirse masivamente como parte de campañas de malware, dejando de ser una herramienta de espionaje estatal o experimento académico para convertirse en una herramienta criminal de uso extendido.

Cuál es el objetivo

El objetivo del keylogging es capturar de manera encubierta todas las pulsaciones de teclado (y en versiones más avanzadas, también clics del mouse, capturas de pantalla o texto copiado al portapapeles) que realiza un usuario en un dispositivo, con el fin de extraer información sensible como nombres de usuario, contraseñas, números de tarjetas de crédito, mensajes privados o contenido de correos electrónicos, sin que la víctima lo perciba, para luego enviar esos datos al atacante.

Descripción

Un keylogger es una herramienta de hardware o software que permite registrar cada pulsación de tecla en dispositivos como computadoras y smartphones; los datos recopilados pueden almacenarse localmente o enviarse periódicamente y de forma encubierta al propietario de la herramienta. Existen usos legítimos (monitoreo parental, cumplimiento corporativo, pruebas de seguridad con consentimiento), pero cuando se instala sin consentimiento y con intención de explotar la información capturada se convierte en un ataque de ciberseguridad malicioso, generalmente clasificado como una forma de spyware.

Los keyloggers modernos rara vez actúan solos: suelen ser un componente dentro de campañas de malware más amplias (troyanos, infostealers) que combinan el registro de pulsaciones con el robo de cookies de sesión, tokens OAuth y contraseñas almacenadas en el navegador, ampliando el alcance del robo de identidad más allá de lo que un keylogger tradicional puede capturar por sí solo.

Por qué medio se produce (con ejemplos reales)

Los keyloggers se distribuyen principalmente mediante correos de phishing con adjuntos o enlaces maliciosos, descargas de software pirata o modificado, dispositivos USB infectados, y en años recientes, dispositivos comprometidos desde fábrica.

Casos reales documentados:

- Zeus Keylogger (2007): desarrollado y liberado en 2007, se dirigió principalmente a instituciones financieras, combinando funciones de keylogger con robo de credenciales bancarias, y se convirtió en una de las familias de malware financiero más influyentes de la década.

- Portátiles HP (2017): se descubrió que un número significativo de laptops Hewlett-Packard salían de fábrica con un keylogger preinstalado; HP afirmó que la herramienta estaba destinada a diagnosticar el rendimiento del teclado y debía haberse eliminado antes del envío, no siendo un ataque malicioso intencional, aunque generó preocupación pública por su potencial de abuso.
- Distribución vía mod de videojuego (2015): un caso documentado de distribución de keylogger en escenario real ocurrió cuando se empaquetó junto con una modificación (mod) del videojuego Grand Theft Auto V.
- Snake Keylogger (campaña reciente): una variante reciente de este keylogger, también llamado "404 Keylogger" o "KrakenKeylogger", fue distribuida mediante correos de phishing y usaba scripting para evadir la detección, registrando pulsaciones y robando credenciales del navegador antes de enviar los datos a los atacantes mediante bots de Telegram.

Cuál es el porcentaje de envíos por día (o de incidencia/frecuencia)

No existe una fuente confiable con un porcentaje exacto de "envíos por día" específico para keyloggers como categoría aislada. Las estadísticas de la industria miden esta amenaza principalmente en el marco más amplio de "infostealers" (que hoy incluyen o han sustituido en gran medida al keylogging puro) y de correos de phishing como vector de entrega. Los datos verificables más cercanos disponibles son:

- Según Kaspersky Digital Footprint Intelligence, cerca de 10 millones de dispositivos fueron víctimas de malware de robo de datos (incluyendo keyloggers e infostealers) en 2023, con un promedio de 50.9 credenciales de acceso robadas por dispositivo infectado.
- Según el informe de Kaspersky Digital Footprint Intelligence 2025, en 2024 se registraron cerca de 9.29 millones de infecciones por infostealers a nivel mundial (dato observado hasta marzo de 2025).
- El correo de phishing —vía principal de distribución de keyloggers como Snake Keylogger— tuvo un volumen de más de 893 millones de intentos de phishing bloqueados por Kaspersky en 2024, un incremento del 26% respecto a 2023; esta cifra corresponde a phishing en general, no exclusivamente a la entrega de keyloggers, pero constituye el dato de volumen diario/anual más cercano y verificable disponible para este vector de distribución (aproximadamente 2.4 millones de intentos de phishing bloqueados por día en promedio durante 2024).
- Según Kaspersky, las detecciones de malware "password stealer" (categoría que incluye keyloggers) aumentaron un 59% interanual en el período de noviembre 2024 a octubre 2025.

Qué procesos de ataque realiza (fases técnicas)

1. Distribución/entrega: el keylogger llega al dispositivo objetivo mediante un correo de phishing con adjunto malicioso, un enlace a un sitio comprometido, software pirateado, o un dispositivo USB infectado.

2. Instalación y persistencia: el software se instala de forma encubierta, a menudo modificando entradas del registro del sistema o utilizando técnicas de arranque automático para garantizar que se ejecute cada vez que el dispositivo se enciende.
3. Evasión de detección: el keylogger busca evadir soluciones antivirus y de seguridad, empleando técnicas como bajo consumo de recursos, cifrado del propio código o comportamiento sigiloso ("bajo perfil"), lo que explica por qué a menudo evaden los análisis de seguridad rutinarios debido a su reducida huella en el sistema.
4. Interceptación de pulsaciones: el software se engancha (hook) a las funciones del sistema operativo que procesan la entrada del teclado (o, en variantes de hardware, intercepta la señal eléctrica/magnética entre el teclado y el equipo) para capturar cada tecla presionada.
5. Recolección de datos adicionales (en variantes avanzadas): además del texto tecleado, capturas de pantalla periódicas, contenido del portapapeles y, en su convergencia con infostealers modernos, cookies de sesión y tokens de autenticación almacenados en el navegador.
6. Almacenamiento y cifrado local temporal: los datos capturados se almacenan temporalmente en un archivo de registro local, a menudo cifrado para dificultar su análisis si es detectado.
7. Exfiltración: la información se transmite periódicamente al atacante mediante un canal encubierto —correo electrónico, servidor FTP remoto, o en campañas recientes, bots de mensajería como Telegram.
8. Explotación de los datos robados: el atacante utiliza las credenciales y datos obtenidos para fraude financiero, robo de identidad, acceso no autorizado a cuentas, o su venta en mercados clandestinos (dark web/foros de cibercrimen).

Escalada de privilegios

Nombre

Escalada de privilegios (Privilege Escalation), clasificada por el marco MITRE ATT&CK como la táctica TA0004, que agrupa las técnicas mediante las cuales un adversario obtiene permisos de nivel superior a los que originalmente le fueron asignados en un sistema, red o aplicación. Se distinguen dos variantes: escalada vertical (de usuario estándar a administrador o root) y escalada horizontal (de una cuenta a otra cuenta del mismo nivel de privilegio).

Por quién fue creado

La escalada de privilegios no fue "inventada" por una persona: es una categoría de vulnerabilidad inherente a cualquier sistema informático que distinga niveles de acceso entre usuarios, algo presente desde los primeros sistemas operativos multiusuario de tiempo compartido de los años 60 (como Multics y CTSS).

- La base conceptual del problema —cómo un programa con privilegios puede ser engañado para abusar de su autoridad— fue formalizada por Norm Hardy en su artículo "The Confused Deputy: (or why capabilities might have been invented)", publicado en el ACM SIGOPS Operating Systems Review en 1988, y es reconocida como un caso específico de escalada de privilegios.
- Técnicamente, la clase de vulnerabilidad se remonta a los mecanismos de control de acceso de Unix de los años 70-80, en particular el bit SUID/setuid, cuyo uso indebido en binarios mal escritos (por ejemplo, invocar comandos sin ruta absoluta, vulnerable a "PATH hijacking") es una de las técnicas de escalada de privilegios locales más antiguas y documentadas en sistemas tipo Unix.
- Como marco de clasificación formal, MITRE institucionalizó la escalada de privilegios como una táctica independiente (TA0004) dentro de MITRE ATT&CK, catalogando actualmente 13 técnicas distintas para lograrla.

Cuál es el objetivo

El objetivo de la escalada de privilegios es que un atacante que ya obtuvo un punto de apoyo inicial en un sistema —normalmente con permisos limitados— consiga elevar ese nivel de acceso hasta alcanzar privilegios de administrador, root o cuenta de dominio, para poder ejecutar acciones que de otro modo le estarían vedadas: instalar malware persistente, desactivar controles de seguridad, acceder a datos sensibles, moverse lateralmente hacia otros sistemas de la red, o tomar control total de la infraestructura. Es un paso intermedio —no el objetivo final— dentro de casi todas las cadenas de ataque avanzadas (APT), ya que rara vez el punto de entrada inicial otorga por sí solo el nivel de acceso necesario para causar un daño significativo.

Descripción

La escalada de privilegios consiste en explotar un error de software, un fallo de diseño o un descuido de configuración en un sistema operativo o aplicación para obtener acceso a recursos normalmente protegidos frente a un usuario o aplicación con menos privilegios. Es una fase crítica dentro de la cadena de ataque (kill chain): tras el acceso inicial —logrado típicamente mediante phishing, robo de credenciales o explotación de una vulnerabilidad—, el atacante rara vez posee de entrada los permisos necesarios para causar un daño significativo, por lo que recurre a la escalada de privilegios para profundizar su control.

Es importante distinguir sus dos variantes:

- Escalada vertical (privilege elevation): el atacante parte de una cuenta de bajo privilegio e intenta obtener control sobre una cuenta de superusuario o administrador de dominio.

- Escalada horizontal: el atacante toma el control de una cuenta y luego expande ese control hacia otras cuentas de privilegio similar.

Las estadísticas de la industria confirman su centralidad como categoría de vulnerabilidad: según el Microsoft Vulnerabilities Report 2025 de BeyondTrust (12.ª edición), las vulnerabilidades de Elevación de Privilegio (EoP) representaron el 40% (554 de 1,360) de todas las vulnerabilidades reportadas de Microsoft en 2024, siendo la categoría dominante por quinto año consecutivo; en 2023 la proporción fue idéntica —40% (490 de aproximadamente 1,292–1,300)—, consolidando a la escalada de privilegios como la categoría de vulnerabilidad más común del ecosistema Microsoft durante varios años seguidos.

Por qué medio se produce (con ejemplos reales)

La escalada de privilegios se produce explotando errores de programación (condiciones de carrera, corrupción de memoria, manejo incorrecto de argumentos), configuraciones erróneas (binarios SUID mal escritos, permisos excesivos en cuentas de servicio), o abuso de funcionalidades legítimas del sistema (herramientas como sudo, pkexec, Mimikatz o PsExec).

Casos reales documentados:

- Dirty COW (CVE-2016-5195, 2016): una vulnerabilidad de condición de carrera en la forma en que el subsistema de memoria del kernel de Linux manejaba la ruptura de copy-on-write (COW) de asignaciones de memoria privadas de solo lectura. Permitía que un usuario local sin privilegios obtuviera acceso de escritura a mapeos de memoria normalmente de solo lectura, y así modificar archivos setuid existentes para elevar sus privilegios hasta obtener acceso root. El fallo estuvo presente en el kernel desde 2007 (versión 2.6.22) y no fue descubierto públicamente hasta 2016 por el investigador Phil Oester; no deja rastros en los registros del sistema, lo que dificulta su detección forense.
- PwnKit (CVE-2021-4034, 2022): descubierta por el equipo de investigación de Qualys, esta vulnerabilidad en la herramienta pkexec de Polkit —presente en prácticamente todas las distribuciones Linux principales (Ubuntu, Debian, Fedora, RHEL, CentOS)— permitía a un usuario local sin privilegios ejecutar código arbitrario como root, manipulando variables de entorno que pkexec no validaba correctamente. El fallo llevaba presente en el código desde mayo de 2009 —más de 12 años sin ser detectado como vulnerabilidad— y su explotación era extremadamente sencilla, sin requerir ninguna condición especial.
- Stuxnet (2010): el gusano informático dirigido contra el programa nuclear de Irán utilizó un total de cinco vulnerabilidades, cuatro de ellas de tipo día cero (zero-day), dos de las cuales eran específicamente de escalada de privilegios: CVE-2010-2743 (vulnerabilidad del kernel de Windows) y CVE-2010-2772 (vulnerabilidad del Programador de Tareas de Windows), que le

permitían pasar de una ejecución con privilegios limitados a obtener privilegios de nivel SYSTEM en las máquinas infectadas, un hito sin precedentes hasta entonces en el uso combinado de múltiples días cero por una sola pieza de malware.

Cuál es el porcentaje de envíos por día (o de incidencia/frecuencia)

No existe una fuente confiable que reporte un "porcentaje de envíos por día" para la escalada de privilegios, ya que —al igual que con CSRF y el keylogging— no es una campaña de distribución masiva sino una técnica/fase dentro de un ataque más amplio. La métrica más cercana, verificable y con respaldo directo de fuente primaria es la proporción de vulnerabilidades de esta categoría sobre el total reportado anualmente:

- Según el Microsoft Vulnerabilities Report 2025 de BeyondTrust (12.ª edición), las vulnerabilidades de Elevación de Privilegio representaron el 40% (554 de 1,360) del total de vulnerabilidades de Microsoft reportadas en 2024, siendo la categoría líder por quinto año consecutivo.
- El mismo informe, en su edición anterior (2024, 11.ª edición), reportó que la Elevación de Privilegio representó también el 40% (490 de ~1,292–1,300) de las vulnerabilidades de Microsoft en 2023, aunque el número absoluto de incidentes bajó un 31% respecto a 2022 (de 715 a 490).
- No existe un desglose equivalente y verificable de "incidencia diaria" para la escalada de privilegios en general (fuera del ecosistema Microsoft), por lo que el dato del 40% anual es la aproximación más sólida y citable disponible.

Qué procesos de ataque realiza (fases técnicas)

1. Acceso inicial: el atacante obtiene un primer punto de apoyo en el sistema, típicamente con privilegios limitados, mediante phishing, robo de credenciales, ingeniería social o la explotación de una vulnerabilidad de acceso remoto.
2. Reconocimiento del entorno (enumeración): una vez dentro, el atacante examina la configuración del sistema en busca de binarios SUID mal configurados, servicios ejecutándose con privilegios excesivos, contraseñas almacenadas en texto plano, tareas programadas mal protegidas, o software desactualizado con vulnerabilidades conocidas.
3. Identificación del vector de escalada: se selecciona la técnica específica a explotar —una falla de software (como una condición de carrera o corrupción de memoria), un error de configuración (permisos excesivos, PATH hijacking), o el abuso de una funcionalidad legítima (herramientas como sudo, PsExec o Mimikatz).
4. Explotación: el atacante ejecuta el exploit correspondiente —por ejemplo, un exploit de condición de carrera como en Dirty COW, o la manipulación de variables de entorno como en

PwnKit— para forzar al sistema a otorgarle privilegios superiores a los asignados originalmente.

5. Obtención de privilegios elevados: como resultado directo de la explotación, el atacante consigue una sesión o proceso con privilegios de administrador, root o cuenta de dominio, según el tipo de escalada (vertical) lograda.
6. Consolidación y persistencia: con los nuevos privilegios, el atacante suele desactivar mecanismos de defensa (antivirus, logging), crear nuevas cuentas privilegiadas o instalar puertas traseras para asegurar acceso continuo aunque se cierre la sesión original.
7. Movimiento lateral y explotación del objetivo final: con privilegios elevados, el atacante se desplaza hacia otros sistemas de la red (movimiento lateral) en busca de activos de mayor valor, y ejecuta el objetivo último del ataque: exfiltración de datos, despliegue de ransomware, sabotaje (como en el caso de Stuxnet) o compromiso total de la infraestructura.

Ataque a la cadena de suministro (Supply Chain Attack)

Nombre

Ataque a la cadena de suministro (Supply Chain Attack), también llamado ataque a la cadena de suministro de software (software supply chain attack) cuando el vector es específicamente software. Se le conoce también como "ataque de terceros" (third-party attack) o "ataque de confianza transitiva", ya que compromete a una organización no de forma directa, sino a través de un proveedor, herramienta o componente de software en el que esa organización confía.

Por quién fue creado

Al igual que CSRF y la escalada de privilegios, no existe un único "creador" del ataque a la cadena de suministro: es una categoría de amenaza que fue anticipada teóricamente antes de materializarse en incidentes masivos.

- Origen conceptual (1974): Paul Karger y Roger Schell, en su evaluación de seguridad del sistema Multics para la Fuerza Aérea de EE. UU., describieron por primera vez cómo un atacante podría insertar una puerta trasera (trap door) en un compilador que se mantuviera a sí misma incluso cuando el compilador fuera recompilado, ya que el compilador de PL/I estaba escrito en su propio lenguaje.
- Formalización pública (1984): Ken Thompson, cocreador de Unix, popularizó este concepto en su célebre discurso de aceptación del Premio Turing, "Reflections on Trusting Trust", publicado en Communications of the ACM. Thompson demostró cómo modificar un compilador de C para insertar una puerta trasera en el comando de login de Unix sin dejar rastro en el código fuente, y explicó que el compilador comprometido podía reconocer y reinsertar automáticamente la

puerta trasera en futuras versiones de sí mismo durante su propia recompilación, creando una cadena autopropagable de software comprometido indetectable mediante la sola inspección del código fuente.

- Primeros ataques reales documentados: según el análisis académico "Journey to the Center of Software Supply Chain Attacks", los primeros ataques conocidos a la cadena de suministro de software de código abierto (OSS) datan de 2010, con la inserción de una puerta trasera en el código fuente de ProFTPD y el caso de la "Operación Aurora"; entre 2010 y 2016 los ataques consistieron principalmente en inyección de código malicioso en el código fuente o durante el proceso de compilación, y ya en 2017 se detectó el primer ataque que explotaba la técnica de "confusión de nombres con paquetes legítimos" (typosquatting) en repositorios como PyPI, técnica que hoy es una de las más explotadas.

Cuál es el objetivo

El objetivo de un ataque a la cadena de suministro es comprometer a una organización no atacándola de forma directa, sino manipulando un producto de software o hardware que la organización utiliza y que es producido o mantenido por un tercero de confianza. Al infiltrar el punto más débil o menos vigilado de la cadena —un proveedor de software, una biblioteca de código abierto, una herramienta de desarrollo o un componente de hardware—, el atacante puede alcanzar simultáneamente a un número muy grande de víctimas finales a través de un único punto de compromiso, maximizando el impacto por cada esfuerzo de intrusión. El código malicioso se introduce muy "aguas arriba" (upstream) respecto a la víctima final, lo que añade una complejidad considerable para su mitigación, ya que el usuario final depende tanto del fabricante del producto como del proveedor original de código abierto para que publiquen los parches correspondientes.

Descripción

Un ataque a la cadena de suministro se diferencia de una intrusión tradicional en que no inyecta código malicioso directamente en el entorno del objetivo, sino que arma (weaponiza) procesos y actualizaciones legítimas, aprovechando que las aplicaciones y servicios de terceros suelen requerir privilegios de acceso y comunicación significativos para funcionar, lo que dificulta bloquearlos preventivamente sin afectar la operación del negocio. Puede clasificarse en tres tipos según su punto de origen: ataques a la cadena de suministro de software (código fuente, herramientas de compilación, actualizaciones), de hardware (manipulación de componentes físicos como servidores o infraestructura de red) y de firmware.

Los ataques a la cadena de suministro de software representan hoy un riesgo sistémico —no solo para una empresa aislada, sino para la continuidad de negocio, la estabilidad económica e incluso la seguridad nacional—, al punto de que el 12 de mayo de 2021 el gobierno de EE. UU. emitió una Orden

Ejecutiva sobre la Mejora de la Ciberseguridad de la Nación con una sección específicamente dedicada a la seguridad de la cadena de suministro de software, en respuesta directa a incidentes como el de SolarWinds.

Por qué medio se produce (con ejemplos reales)

Un ataque a la cadena de suministro se produce principalmente mediante: la inyección de código malicioso en el proceso de compilación o construcción (build) de software legítimo; la publicación de paquetes maliciosos en repositorios de código abierto (npm, PyPI, NuGet) haciéndose pasar por paquetes populares (typosquatting) o mediante el secuestro de cuentas de mantenedores legítimos; y la manipulación de componentes de hardware o firmware durante la fabricación o distribución física.

Casos reales documentados:

- SolarWinds / SUNBURST (2020): un grupo de amenaza persistente avanzada identificado por MITRE ATT&CK como APT29 obtuvo acceso a la red de SolarWinds en septiembre de 2019, probó inyecciones de código en octubre de 2019, e insertó el backdoor SUNBURST en el código fuente de la plataforma Orion en febrero de 2020. Entre marzo y junio de 2020, SolarWinds distribuyó, sin saberlo, actualizaciones troyanizadas de Orion firmadas digitalmente a sus clientes; más de 18,000 organizaciones instalaron las actualizaciones comprometidas, entre ellas múltiples agencias del gobierno de EE. UU. y empresas como Cisco, Intel y Microsoft. El compromiso no fue detectado hasta el 13 de diciembre de 2020, cuando la firma FireEye lo descubrió mientras investigaba el robo de sus propias herramientas internas de Red Team.
- XZ Utils backdoor (2024): un ejemplo reciente y ampliamente citado por Sonatype de sofisticación creciente en ataques a la cadena de suministro de código abierto, en el que se insertó una puerta trasera en la utilidad de compresión XZ Utils, ampliamente utilizada en distribuciones Linux.
- Typosquatting en PyPI (desde 2017): el primer ataque documentado de este tipo consistió en subir a PyPI paquetes con nombres que imitaban a proyectos populares como urllib3, para engañar a desarrolladores que cometían errores de tipeo al instalar dependencias.

Cuál es el porcentaje de envíos por día (o de incidencia/frecuencia)

No existe una fuente confiable que reporte un "porcentaje de envíos por día" para los ataques a la cadena de suministro, ya que no se trata de una campaña de envío masivo de mensajes, sino de la inserción de código malicioso en paquetes o actualizaciones de software distribuidos de forma continua. Los datos verificables más cercanos, medidos como volumen acumulado y crecimiento interanual de paquetes maliciosos de código abierto, provienen del informe anual "State of the Software Supply Chain" de Sonatype, la fuente de referencia de la industria en esta materia:

- Según el 10.º informe anual de Sonatype (2024), se identificaron 512,847 paquetes maliciosos de código abierto solo en el último año registrado, lo que representa un incremento interanual del 156%, acumulando un total de 704,102 paquetes maliciosos identificados desde que Sonatype comenzó a rastrear esta métrica en 2019.
- El índice de Malware de Código Abierto de Sonatype correspondiente al segundo trimestre de 2025 reportó un total acumulado de 845,204 paquetes maliciosos, un incremento del 188% respecto al mismo trimestre del año anterior, evidenciando que el ritmo de crecimiento se ha acelerado aún más.
- Según el mismo informe, el registro npm concentra aproximadamente el 98.5% de los paquetes maliciosos identificados, siendo el ecosistema de mayor riesgo dentro de la cadena de suministro de software de código abierto.
- No existe un desglose oficial de "paquetes maliciosos publicados por día", pero dividiendo el total de 512,847 nuevos paquetes maliciosos de 2024 entre 365 días se obtiene un promedio aproximado de 1,400 paquetes maliciosos nuevos por día durante ese año —cálculo propio a partir del dato anual verificado de Sonatype, no una cifra publicada directamente por la fuente —.

Qué procesos de ataque realiza (fases técnicas) Selección del eslabón débil: el atacante identifica un proveedor, biblioteca de código abierto, herramienta de compilación o componente de hardware ampliamente utilizado por sus organizaciones objetivo, pero con controles de seguridad más débiles que los de las víctimas finales.

Compromiso inicial del proveedor o repositorio: el atacante obtiene acceso a la red, el entorno de compilación (build) o la cuenta de mantenedor del proveedor —en el caso de SolarWinds, mediante acceso no autorizado a su red interna; en el caso de paquetes open source, mediante secuestro de cuentas de mantenedores o publicación directa de paquetes con nombres engañosos (typosquatting).

Inyección del código malicioso: se inserta la puerta trasera o payload malicioso directamente en el código fuente, en el proceso de construcción (build), o en una nueva versión del paquete/actualización, procurando que el cambio pase inadvertido en revisiones de código o auditorías rutinarias.

Firma y distribución legítima: el software comprometido se firma digitalmente y se distribuye a través de los canales oficiales y de confianza del proveedor (actualizaciones automáticas, repositorios oficiales de paquetes), lo que hace que las víctimas instalen el malware voluntariamente, confiando en la legitimidad del origen.

Propagación masiva a través de la base de clientes: el software troyanizado se instala en todos los sistemas que actualizan o descargan el componente comprometido, alcanzando en un solo evento a miles de organizaciones simultáneamente sin que el atacante tenga que comprometerlas una por una.

Activación selectiva y evasión de defensas: en campañas sofisticadas, el malware permanece inactivo (dormant) y solo se activa en objetivos de alto valor previamente seleccionados, evitando llamar la atención en la mayoría de las instalaciones y dificultando su detección temprana.
Explotación del acceso obtenido: una vez activo en el entorno de la víctima final, el atacante utiliza el acceso logrado para exfiltrar datos, moverse lateralmente dentro de la red, desplegar payloads adicionales o mantener persistencia a largo plazo dentro de la infraestructura comprometida.

Ransomware

Nombre

Ransomware, término que combina la palabra inglesa “ransom” (rescate) con el sufijo “-ware” de software. Se trata de un tipo de malware que restringe el acceso a un sistema informático o a los archivos que contiene, generalmente mediante cifrado, y exige a la víctima el pago de un rescate económico para restaurar el acceso.

Por quién fue creado

El origen del ransomware se remonta a 1989, cuando el biólogo evolutivo Joseph L. Popp, investigador de Harvard y consultor de la Organización Mundial de la Salud, distribuyó cerca de 20 000 disquetes titulados “AIDS Information Introductory Diskette” entre asistentes de una conferencia de la OMS sobre el sida realizada en Estocolmo, así como a instituciones médicas de más de 90 países (Stormshield, 2024; Xataka, 2021). El disquete contenía el llamado “troyano SIDA” (AIDS Trojan o PC Cyborg), que tras un número determinado de reinicios del equipo cifraba los nombres de los archivos del disco duro y exigía el envío de 189 dólares a un apartado postal en Panamá para recibir el software de recuperación (Xataka, 2021). Popp fue identificado y detenido por las autoridades británicas, pero el proceso judicial no llegó a una condena firme debido a que fue declarado no apto para enfrentar juicio (Cosmikal, 2025). Este incidente es considerado el primer caso documentado de ransomware de la historia de la informática (Grokipedia, 2026; Hipertextual, 2022). A partir de 1996, los criptógrafos Adam Young y Moti Yung formalizaron académicamente el concepto al introducir el uso de criptografía asimétrica en este tipo de ataques, dando origen al campo de estudio conocido como criptovirología (Hipertextual, 2022).

Cuál es el objetivo

El objetivo principal del ransomware es la extorsión económica: el atacante busca imposibilitar el acceso legítimo a datos o sistemas críticos de la víctima —mediante cifrado, bloqueo de pantalla o

ambos— para forzar el pago de un rescate, habitualmente en criptomonedas, a cambio de la clave de descifrado. En las variantes modernas de doble y triple extorsión, el objetivo se amplía: además de cifrar la información, el atacante la exfiltra previamente y amenaza con publicarla o venderla si no se paga, e incluso presiona directamente a los clientes o socios de la víctima (Ransomware Authority, 2026; Vectra AI, 2026).

Descripción

Por qué medio se produce (con ejemplos reales)

El ransomware se distribuye principalmente a través de correos electrónicos de phishing con archivos adjuntos o enlaces maliciosos, explotación de vulnerabilidades en aplicaciones expuestas a internet, compromiso de credenciales de acceso remoto (RDP y VPN) y, cada vez con mayor frecuencia, mediante el acceso comprado a intermediarios de acceso inicial (Initial Access Brokers) que ya han vulnerado una red y revenden ese acceso a grupos de ransomware (Vectra AI, 2026). También es habitual el compromiso de proveedores externos y cadenas de suministro. Ejemplos reales documentados incluyen el ataque de 2021 contra Colonial Pipeline en Estados Unidos, que obligó a paralizar el suministro de combustible (Red Hot Cyber, 2025), y la ola de ataques de 2025 contra las cadenas minoristas Marks & Spencer, Co-op y Harrods en el Reino Unido, atribuidos al grupo Scattered Spider, así como el ataque al fabricante cervecero japonés Asahi reivindicado por el grupo Qilin (NCC Group, 2026).

Cuál es el porcentaje de envíos por día

No existe una fuente que reporte de manera oficial un “porcentaje de envíos diarios” de ransomware, ya que los ataques no se contabilizan como campañas de envío masivo sino como incidentes confirmados contra organizaciones. La aproximación más cercana y verificable proviene del informe anual de NCC Group (2026), que registró 7 874 ataques de ransomware a nivel mundial durante 2025, un incremento del 50 % respecto a 2024; esto equivale a un promedio aproximado de 21,6 ataques diarios a nivel mundial, con picos de hasta 1 093 ataques en un solo mes (febrero de 2025). En términos de incidencia dentro de brechas de seguridad ya confirmadas, el Data Breach Investigations Report 2025 de Verizon determinó que el ransomware estuvo presente en el 44 % de todas las brechas analizadas —frente al 32 % del año anterior—, alcanzando el 88 % de los casos en pequeñas y medianas empresas y el 39 % en grandes empresas (Halcyon, 2025; Verizon, 2025).

Qué procesos de ataque realiza

De acuerdo con CISA (2023) y con el detalle operativo documentado por Flashpoint (2026), un ataque de ransomware sigue típicamente las siguientes fases: (1) reconocimiento y selección del objetivo, donde el atacante identifica organizaciones vulnerables; (2) acceso inicial, logrado mediante phishing, explotación de vulnerabilidades en aplicaciones expuestas o compra de credenciales robadas; (3) consolidación y movimiento lateral, en la que el atacante escala privilegios y se desplaza por la red utilizando herramientas como Cobalt Strike, Mimikatz o PsExec para alcanzar servidores de respaldo y controladores de dominio; (4) exfiltración de datos previa al cifrado, característica del modelo de doble extorsión, mediante herramientas de transferencia hacia infraestructura del atacante; (5) despliegue y ejecución del cifrado, incluyendo la eliminación de copias de seguridad y de instantáneas de volumen (shadow copies) para impedir la recuperación; (6) extorsión y comunicación, con la nota de rescate y, frecuentemente, la amenaza de publicar los datos robados en portales de filtración; y (7) recuperación y mitigación por parte de la víctima, que incluye la decisión de pagar o no el rescate y la restauración de sistemas a partir de copias de seguridad no comprometidas (CISA, 2023; Flashpoint, 2026).

Ataque de fuerza bruta

Nombre

Ataque de fuerza bruta (brute-force attack), también conocido como “exhaustive key search” o búsqueda exhaustiva de claves en criptografía.

Por quién fue creado

A diferencia del ransomware o la inyección SQL, el ataque de fuerza bruta no tiene un autor ni una fecha de creación puntual, pues corresponde a un principio matemático de la criptografía y del análisis combinatorio: probar sistemáticamente todas las combinaciones posibles de una clave hasta encontrar la correcta (Wikipedia, 2026a). El concepto se aplicó desde los inicios de la criptografía computacional del siglo XX y se popularizó como técnica de ataque informático con el desarrollo de los primeros sistemas de autenticación por contraseña en los sistemas Unix durante las décadas de 1970 y 1980. Su formalización como categoría de amenaza en aplicaciones web fue realizada por el proyecto OWASP (Open Worldwide Application Security Project), que la documenta dentro de su catálogo de ataques comunes y la clasifica también dentro de su proyecto OWASP Automated Threats to Web Applications bajo el identificador OAT-007, “Credential Cracking” (F5, s.f.; OWASP Foundation, s.f.-a).

Cuál es el objetivo

El objetivo del ataque de fuerza bruta es descubrir de forma no autorizada una contraseña, una clave criptográfica, un identificador de sesión o cualquier otro secreto de autenticación, probando de manera sistemática y automatizada todas las combinaciones posibles de caracteres o una lista amplia de valores hasta dar con la combinación correcta (OWASP Foundation, s.f.-b). Su finalidad final suele ser obtener acceso no autorizado a cuentas de usuario, paneles administrativos, servicios de escritorio remoto (RDP) o contenido oculto dentro de una aplicación web, como directorios o archivos no enlazados públicamente.

Descripción

Por qué medio se produce (con ejemplos reales)

Los ataques de fuerza bruta se producen principalmente contra formularios de autenticación web (mediante peticiones HTTP GET o POST automatizadas), servicios de acceso remoto como el Protocolo de Escritorio Remoto (RDP) y SSH, APIs sin límite de intentos, y paneles de administración de sitios web (OWASP Foundation, s.f.-b). El atacante emplea herramientas automatizadas como Hydra, Medusa, Burp Suite o DirBuster, que envían miles de combinaciones de usuario y contraseña por minuto, en muchos casos distribuidas a través de listas de proxies o redes de bots para evitar el bloqueo por dirección IP (OWASP Foundation, s.f.-b). Un caso real ampliamente documentado es el incremento masivo de ataques de fuerza bruta contra el protocolo RDP durante la pandemia de COVID-19: Kaspersky detectó que estos ataques pasaron de aproximadamente 93,1 millones de intentos mensuales en febrero de 2020 a 277,4 millones en marzo del mismo año, coincidiendo con la migración masiva al teletrabajo (Kaspersky, 2020).

Cuál es el porcentaje de envíos por día

Tampoco existe una fuente que publique un porcentaje diario exacto y global de ataques de fuerza bruta, dado que su volumen varía enormemente según el protocolo y la región monitoreada. La aproximación más cercana y verificable corresponde nuevamente a la telemetría de Kaspersky sobre ataques de fuerza bruta contra el protocolo RDP: entre enero y noviembre de 2020 se detectaron 3300 millones de estos ataques a nivel mundial, lo que equivale a un promedio aproximado de 10,8 millones de intentos de fuerza bruta por día contra RDP durante ese periodo; solo en noviembre de 2020 se registró un máximo mensual de 409 millones de ataques, equivalente a unos 13,6 millones por día, y en febrero de 2021 se contabilizaron 377,5 millones, cerca de 13,5 millones diarios (Kaspersky, 2020; Securelist, 2021). Estas cifras corresponden específicamente a ataques contra RDP detectados por los

productos de Kaspersky y no representan la totalidad de los ataques de fuerza bruta a nivel mundial contra todos los protocolos y servicios.

Qué procesos de ataque realiza

Un ataque de fuerza bruta sigue, de manera general, las siguientes fases: (1) reconocimiento del objetivo, en el que el atacante identifica el servicio expuesto (formulario de login, RDP, SSH, API) y determina si existen mecanismos de bloqueo o limitación de intentos; (2) preparación del diccionario o del espacio de claves, generando combinaciones exhaustivas de caracteres o reutilizando listas de nombres de usuario y contraseñas conocidas; (3) automatización del ataque mediante herramientas especializadas que envían peticiones repetidas contra el servicio objetivo; (4) evasión de controles de seguridad, rotando direcciones IP a través de proxies o redes de bots y alternando nombres de usuario para eludir bloqueos por cuenta; (5) análisis de las respuestas del servidor para identificar intentos exitosos, revisando códigos de estado HTTP o mensajes de error; y (6) explotación del acceso obtenido, que puede derivar en robo de datos, movimiento lateral dentro de la red o instalación de malware adicional una vez lograda la autenticación (OWASP Foundation, s.f.-b; F5, s.f.).

SQL Injection

Nombre

Inyección SQL o SQL injection (SQLi), técnica de ataque que consiste en insertar o “inyectar” sentencias de Lenguaje de Consulta Estructurado (SQL) dentro de los campos de entrada de una aplicación para alterar la consulta que esta ejecuta contra su base de datos.

Por quién fue creado

La primera documentación pública conocida de esta técnica fue realizada por el investigador de seguridad Jeff Forristal, bajo el seudónimo “rain.forest.puppy”, en el número 54 de la revista underground Phrack, publicado el 25 de diciembre de 1998, bajo el título “NT Web Technology Vulnerabilities” (Grokipedia, 2026; Malwarebytes, 2024). En su artículo, Forristal describió cómo era posible “acoplar” comandos SQL adicionales dentro de campos de entrada normales —como nombre o número de teléfono— de un servidor Microsoft SQL Server 6.5 conectado mediante ODBC a páginas ASP sobre IIS 4.0, logrando que el servidor revelara información sensible (ExtraHop, s.f.; Vice, 2024). Aunque Forristal notificó la vulnerabilidad a Microsoft, la compañía no la consideró un problema en ese momento (Malwarebytes, 2024). La técnica no atrajo mayor atención de la comunidad de seguridad informática hasta el año 2002, cuando el investigador Jeremiah Jacks demostró una vulnerabilidad de

inyección SQL en el sitio de comercio electrónico Guess.com que exponía más de 200 000 registros de clientes, incluyendo números de tarjetas de crédito (Tia Hub, s.f.).

Cuál es el objetivo

El objetivo de un ataque de inyección SQL es manipular las consultas que una aplicación realiza a su base de datos para leer, modificar o eliminar información a la que el atacante no debería tener acceso, sortear mecanismos de autenticación, o —en los casos más graves— escalar privilegios hasta lograr ejecución remota de comandos en el servidor mediante consultas apiladas (stacked queries) (OWASP Foundation, 2021; Tia Hub, s.f.). En síntesis, busca comprometer la confidencialidad, integridad o disponibilidad de los datos almacenados en un sistema gestor de bases de datos relacional.

Descripción

Por qué medio se produce (con ejemplos reales)

La inyección SQL se produce cuando una aplicación web construye consultas a la base de datos concatenando directamente datos proporcionados por el usuario —a través de formularios, parámetros de URL, cabeceras HTTP o cookies— sin validarlos, filtrarlos ni utilizar consultas parametrizadas (OWASP Foundation, 2021). El vector de entrada más común son los campos de formularios de inicio de sesión, buscadores internos y parámetros de identificadores en la URL. Ejemplos reales documentados incluyen el ataque de 2007 contra la cadena de tiendas 7-Eleven, en el que un grupo de atacantes utilizó inyección SQL para infiltrarse en la red corporativa y robar datos de tarjetas de crédito, el mismo grupo que posteriormente atacó a la procesadora de pagos Heartland Payment Systems (Foresite, 2025); la brecha masiva de Lilupophilupop, que en un solo mes de finales de 2011 e inicios de 2012 comprometió más de un millón de páginas web mediante inyección SQL automatizada (Invicti, 2013); y la vulnerabilidad identificada en 2019 en la plataforma del videojuego Fortnite, que exponía a los usuarios a un riesgo de inyección SQL y fue corregida antes de ser explotada de forma conocida (Foresite, 2025).

Cuál es el porcentaje de envíos por día

No existe una cifra oficial de “envíos diarios” de ataques de inyección SQL, puesto que —a diferencia del ransomware o el phishing masivo— no se distribuye por campañas de envío, sino que se ejecuta contra aplicaciones específicas mediante peticiones HTTP manipuladas. La aproximación más cercana y verificable es la tasa de incidencia reportada por el proyecto OWASP en su informe Top 10 de 2021: la categoría de inyección (que incluye SQL injection como una de sus vulnerabilidades más

representativas, identificada como CWE-89) fue evaluada en el 94 % de las aplicaciones analizadas, con una tasa de incidencia máxima del 19 % y una tasa de incidencia promedio del 3 %, registrando 274 000 ocurrencias sobre el total de aplicaciones evaluadas por los contribuyentes de datos de OWASP (OWASP Foundation, 2021). De manera complementaria, un análisis de vulnerabilidades de Foresite (2025) indica que el 12 % de las vulnerabilidades internas detectadas en evaluaciones de seguridad corresponden a inyección SQL, mientras que esta técnica está presente en el 42 % de las vulnerabilidades críticas de aplicaciones expuestas a internet.

Qué procesos de ataque realiza

Un ataque de inyección SQL sigue habitualmente las siguientes fases técnicas: (1) reconocimiento y detección de la vulnerabilidad, en la que el atacante introduce caracteres especiales (comillas simples, comentarios SQL, operadores lógicos) en los campos de entrada para observar si la aplicación devuelve errores de sintaxis SQL u otro comportamiento anómalo; (2) identificación (fingerprinting) del motor de base de datos y de la estructura de la consulta original, a menudo apoyándose en los mensajes de error devueltos por el servidor; (3) selección de la técnica de inyección más adecuada, entre las que destacan la inyección basada en errores (error-based), la basada en uniones (UNION-based), la ciega booleana (boolean-based blind) y la basada en tiempo (time-based blind), utilizada cuando la aplicación no muestra mensajes de error visibles (Tia Hub, s.f.); (4) extracción progresiva de información de la base de datos, como nombres de tablas, columnas y registros sensibles; y (5) explotación avanzada, que puede incluir la modificación o eliminación de datos, la evasión de mecanismos de autenticación, o —en el caso de bases de datos con privilegios elevados y consultas apiladas— la ejecución de comandos del sistema operativo subyacente, escalando el impacto a un compromiso total del servidor (OWASP Foundation, 2021; Tia Hub, s.f.).

Ataque de día cero

Nombre

Ataque de día cero (zero-day attack), denominado así porque explota una vulnerabilidad de software desconocida para el fabricante o para el público en general, de modo que este dispone de “cero días” de anticipación para desarrollar y distribuir un parche antes de que sea explotada (Wikipedia, 2026b).

Por quién fue creado

A diferencia de otras técnicas de esta investigación, el ataque de día cero no fue “inventado” por una persona identificable, sino que es una categoría que describe cualquier explotación de una

vulnerabilidad desconocida en el momento del ataque; el término proviene de la industria de distribución de software y videojuegos, donde “día cero” se refería originalmente a la fecha oficial de lanzamiento de un producto, y pasó a la seguridad informática para describir vulnerabilidades explotadas antes de que exista un parche disponible. El caso que popularizó y consolidó el concepto ante el público general fue Stuxnet, un gusano informático descubierto en 2010 —aunque activo desde 2005 según investigaciones posteriores— que aprovechó al menos cuatro vulnerabilidades de día cero en Windows para sabotear las centrifugadoras de enriquecimiento de uranio de la planta de Natanz, en Irán, y que se atribuye conjuntamente a Estados Unidos e Israel, sin reconocimiento oficial (Cyte, 2025; Perimeter 81, 2024). Actualmente, el seguimiento sistemático y la publicación de estadísticas sobre vulnerabilidades de día cero explotadas activamente están a cargo de organizaciones especializadas como el Google Threat Intelligence Group (antes Google Project Zero y Threat Analysis Group) y la firma de respuesta a incidentes Mandiant (Google Cloud, 2025).

Cuál es el objetivo

El objetivo de un ataque de día cero es aprovechar una vulnerabilidad de software o hardware que aún no ha sido descubierta ni corregida por el fabricante para comprometer un sistema antes de que exista una defensa disponible, maximizando así la probabilidad de éxito y minimizando la capacidad de detección de la víctima (Vectra AI, 2026). Según el fin del atacante, puede orientarse al espionaje estatal, al sabotaje de infraestructura crítica, al robo de datos con fines financieros o a la vigilancia de individuos específicos mediante herramientas de vigilancia comercial (Bright Defense, 2026).

Descripción

Por qué medio se produce (con ejemplos reales)

Los ataques de día cero se producen a través de múltiples vectores: correos de phishing dirigido (spear phishing) con documentos maliciosos, descargas “drive-by” desde sitios web comprometidos, explotación remota de servicios expuestos a internet —especialmente dispositivos de borde como VPN y firewalls empresariales— y cadenas de exploits combinadas con malware de vigilancia comercial (Deepstrike, 2025; Vectra AI, 2026). Ejemplos reales documentados incluyen el ya mencionado Stuxnet (2010) contra el programa nuclear iraní; el ataque de 2014 contra Sony Pictures Entertainment, en el que se explotaron vulnerabilidades desconocidas para filtrar grandes volúmenes de información confidencial (Comillas, 2024); y las vulnerabilidades de día cero descubiertas a inicios de 2021 en Microsoft Exchange Server, que permitieron a atacantes acceder a cuentas de correo corporativo de miles de organizaciones en todo el mundo antes de que Microsoft publicara las actualizaciones

correspondientes (Comillas, 2024). Según Google Threat Intelligence Group, el 48 % de los días cero explotados en 2025 tuvo como objetivo tecnologías de uso empresarial, como productos de seguridad y redes, en lugar de dispositivos de usuario final (Vectra AI, 2026).

Cuál es el porcentaje de envíos por día

El concepto de "porcentaje de envíos por día" no resulta directamente aplicable a los ataques de día cero, ya que estos no se distribuyen de forma masiva como el phishing o el spam, sino que corresponden a explotaciones puntuales y de alto valor, generalmente dirigidas a objetivos específicos. La aproximación más cercana y verificable es el volumen anual de vulnerabilidades de día cero detectadas activamente explotadas: según Google Threat Intelligence Group, en 2025 se documentaron 90 vulnerabilidades de día cero explotadas en el mundo real, cifra consistente con un rango de entre 60 y 100 casos anuales durante los últimos cuatro años (78 en 2024 y 97 en 2023) (Bright Defense, 2026; Google Cloud, 2025). Esto equivale a un promedio aproximado de 0,25 vulnerabilidades de día cero explotadas por día a nivel mundial, es decir, cerca de una cada cuatro días, considerando únicamente los casos detectados y atribuidos públicamente. En cuanto a su papel dentro de las brechas de seguridad ya confirmadas, el informe M-Trends 2025 de Mandiant determinó que la explotación de vulnerabilidades —incluyendo días cero— fue el vector de acceso inicial más frecuente por quinto año consecutivo, responsable del 33 % de todas las intrusiones investigadas por la firma (Deepstrike, 2025; Vectra AI, 2026).

Qué procesos de ataque realiza

El ciclo de vida de un ataque de día cero comprende, según la descripción técnica de Vectra AI (2026), las siguientes fases: (1) descubrimiento de la vulnerabilidad, ya sea por el propio atacante mediante ingeniería inversa del software o por la adquisición de la información en el mercado negro o a través de intermediarios especializados (broker de exploits); (2) desarrollo del exploit, es decir, la creación del código capaz de aprovechar la falla para ejecutar código arbitrario o escalar privilegios; (3) entrega del exploit a la víctima, mediante correos de phishing dirigido, sitios web comprometidos o explotación directa de un servicio expuesto a internet; (4) explotación y ejecución, momento en que el código malicioso se ejecuta aprovechando la ausencia de parche o firma de detección; (5) post-explotación y persistencia, en la que el atacante instala puertas traseras o mecanismos de acceso permanente para mantener el control del sistema comprometido, evadiendo las herramientas de detección; y (6) divulgación y parcheo, fase final en la que el fabricante toma conocimiento de la vulnerabilidad —ya sea por divulgación responsable o por su explotación pública— y libera una actualización de seguridad, cerrando la ventana de exposición (Google Cloud, 2025; Vectra AI, 2026).

Ataque de diccionario

Nombre

Ataque de diccionario (dictionary attack), técnica de descifrado de contraseñas que consiste en probar sistemáticamente las palabras contenidas en una lista predefinida —o “diccionario”— de términos comunes, contraseñas filtradas previamente y sus variaciones, en lugar de generar combinaciones aleatorias de caracteres como en un ataque de fuerza bruta puro (TechTarget, s.f.).

Por quién fue creado

El ataque de diccionario, como principio, se deriva directamente de las técnicas de criptoanálisis y de descifrado de contraseñas desarrolladas para los primeros sistemas Unix multiusuario de los años setenta y ochenta. Su primera implementación como herramienta de software ampliamente utilizada fue Crack, desarrollada a partir de 1990 por Alec Muffett, administrador de sistemas Unix en la Universidad de Gales en Aberystwyth, quien mejoró el descifrador “pwc” incluido en el paquete de auditoría COPS de Dan Farmer; la primera versión pública de Crack (2.7a) fue publicada en los grupos de noticias Usenet el 15 de julio de 1991, y es considerada el primer descifrador de contraseñas independiente (standalone) para sistemas Unix, además de introducir la generación programable de diccionarios (Wikipedia, 2026c). En 1996 apareció John the Ripper, herramienta de código abierto que combinó ataques de diccionario y de fuerza bruta en un solo programa y que continúa siendo, junto con Hydra y Hashcat, una de las herramientas de referencia en pruebas de penetración y en ataques reales (Ethical Hacking Cheatsheet, s.f.; SpyCloud, 2026).

Cuál es el objetivo

El objetivo de un ataque de diccionario es descubrir de forma no autorizada la contraseña de una cuenta o el valor de una clave criptográfica de manera considerablemente más rápida y eficiente que un ataque de fuerza bruta exhaustivo, aprovechando el hecho de que una gran parte de los usuarios elige contraseñas basadas en palabras reales, nombres propios, patrones predecibles o contraseñas ya filtradas en brechas anteriores (NordPass, s.f.; TechTarget, s.f.). Una vez obtenida la contraseña, el atacante busca apropiarse de la cuenta comprometida para robar información, realizar fraude financiero o utilizarla como punto de entrada hacia sistemas más amplios.

Descripción

Por qué medio se produce (con ejemplos reales)

Los ataques de diccionario se producen de dos formas principales: en línea (online), cuando el atacante prueba repetidamente las palabras del diccionario directamente contra un formulario de inicio de sesión activo, con el riesgo de ser detectado o bloqueado por el sistema; y fuera de línea (offline), cuando el atacante ya posee un archivo con contraseñas cifradas —obtenido de una brecha de datos previa— y compara los hashes de las palabras del diccionario contra ese archivo sin ninguna limitación de intentos ni supervisión (NordPass, s.f.). Los diccionarios utilizados suelen construirse a partir de listas de las contraseñas más comunes —como “123456”, “password” o “qwerty”—, filtraciones de datos previas, nombres propios e información personal disponible públicamente en redes sociales (Expert Insights, 2026). Ejemplos reales documentados incluyen la brecha de datos de LinkedIn de 2012, en la que se expusieron las credenciales de más de 167 millones de usuarios y los atacantes emplearon diccionarios de contraseñas para descifrar los hashes robados, y la brecha de Adobe Systems de 2013, que comprometió información de aproximadamente 38 millones de usuarios mediante el mismo tipo de técnica contra contraseñas cifradas de forma débil (Specops Software, 2025).

Cuál es el porcentaje de envíos por día

No existe una fuente que reporte un porcentaje diario de “envíos” de ataques de diccionario, dado que —al igual que la inyección SQL y el ataque de fuerza bruta— no se trata de una campaña de distribución masiva, sino de un método de descifrado aplicado contra credenciales específicas u obtenidas de brechas previas. La aproximación más cercana y verificable disponible corresponde a la prevalencia de contraseñas débiles, que constituye el factor que determina la eficacia de este tipo de ataque: según el informe de Keeper Security (2026), únicamente el 25 % de los usuarios utiliza contraseñas fuertes y únicas para cada cuenta, lo que implica que el 75 % de los usuarios mantiene cuentas expuestas a este tipo de técnica. De manera complementaria, el análisis de NordPass sobre contraseñas filtradas en 2020 identificó que la contraseña “123456” apareció 2 543 285 veces dentro de la muestra analizada, evidenciando la magnitud del universo de credenciales predecibles que un diccionario de ataque puede explotar con éxito (TechTarget, s.f.).

Qué procesos de ataque realiza

Un ataque de diccionario sigue generalmente las siguientes fases: (1) construcción o adquisición del diccionario, recopilando listas de palabras comunes, nombres, fechas y contraseñas previamente filtradas en brechas de datos públicas; (2) adaptación del diccionario al objetivo, incorporando

variaciones como sustitución de letras por números (por ejemplo, sustituir “a” por “@”), adición de sufijos numéricos o combinación con datos personales de la víctima obtenidos de redes sociales, lo que se conoce como ataque híbrido (Specops Software, 2025); (3) selección del modo de ataque, en línea contra un formulario de autenticación activo o fuera de línea contra un archivo de contraseñas cifradas previamente sustraído; (4) ejecución automatizada mediante herramientas especializadas como John the Ripper, Hashcat o Hydra, que recorren el diccionario probando cada palabra y comparando el resultado cifrado (hash) con el valor objetivo; (5) identificación de coincidencias exitosas, momento en el que se revela la contraseña en texto plano; y (6) explotación del acceso obtenido para el robo de información, fraude o movimiento hacia otros sistemas donde la víctima haya reutilizado la misma contraseña (NordPass, s.f.; ScienceDirect, s.f.; Specops Software, 2025).

Ataque a la cadena de suministro (Supply Chain Attack)

Nombre

Ataque a la cadena de suministro (en inglés, Supply Chain Attack), también conocido como ataque a terceros o ataque de la cadena de valor.

Por quién fue creado

El concepto teórico de comprometer un sistema a través de la cadena de producción de software fue planteado por primera vez por Ken Thompson, cocreador de Unix, en su artículo de 1984 "Reflections on Trusting Trust", donde demostró que un compilador podía modificarse para insertar puertas traseras invisibles en el código fuente (Veracode, s.f.). Sin embargo, los primeros ataques documentados de este tipo contra software de código abierto datan de 2010, con la inserción de una puerta trasera en el código fuente de ProFTPD 1.3.3c y con la denominada "Operación Aurora" (Ceccato, Nucci, Massacci y Sabetta, 2023). El episodio que popularizó masivamente esta categoría de ataque a nivel mundial fue el compromiso de la empresa SolarWinds, descubierto en diciembre de 2020, atribuido a un grupo de amenaza persistente avanzada (APT) vinculado al Servicio de Inteligencia Exterior de Rusia (SVR) (Vectra AI, 2026).

Cuál es el objetivo

El objetivo de este ataque es comprometer a una organización de manera indirecta, manipulando un software, componente de hardware o proceso de actualización producido y mantenido por un tercero de confianza (proveedor, contratista o biblioteca de código abierto), en lugar de atacar directamente las defensas perimetrales de la víctima final. De esta forma, el atacante aprovecha la confianza que la organización deposita en sus proveedores para lograr espionaje, robo de datos, despliegue de ransomware o sabotaje a gran escala, afectando potencialmente a cientos o miles de organizaciones a partir de un único punto de compromiso (ExtraHop, s.f.; Infosec Institute, 2025).

Descripción

Un ataque a la cadena de suministro consiste en insertar código malicioso o componentes comprometidos en un producto legítimo antes de que este llegue al consumidor final, aprovechando que los mecanismos de actualización y distribución de software gozan de un nivel de confianza elevado dentro de las organizaciones (ExtraHop, s.f.).

Por qué medio se produce (con ejemplos)

Este ataque se produce principalmente a través de: la inyección de código malicioso en bibliotecas y paquetes de código abierto (npm, PyPI, Maven), el secuestro del proceso de compilación (build) o de los servidores de actualización de un proveedor de software, la falsificación de certificados de firma digital, y el compromiso de componentes de hardware antes de su distribución. Ejemplos reales documentados incluyen: el ataque SolarWinds Sunburst (2020), en el que se insertó una puerta trasera en las actualizaciones del software Orion, afectando a unas 18 000 organizaciones, entre ellas agencias del gobierno estadounidense (Vectra AI, 2026); la vulneración de la cadena de suministro de Target en 2013, en la que los atacantes ingresaron usando credenciales robadas a Fazio Mechanical Services, un proveedor externo de climatización (Wikipedia, s.f.-a); el ataque a Kaseya VSA (2021), que permitió distribuir ransomware REvil a través de una herramienta de gestión remota utilizada por proveedores de servicios gestionados; y la inserción sistemática de paquetes maliciosos en repositorios como npm y PyPI, una técnica que, según datos recopilados por ExtraHop, ha llevado a que los ataques a la cadena de suministro de software de código abierto se incrementen un 650 % interanual (ExtraHop, s.f.).

Cuál es el porcentaje de envíos por día

A diferencia de ataques masivos de correo (como el phishing), el ataque a la cadena de suministro no se mide en "envíos diarios", ya que no es una campaña de distribución masiva sino la explotación puntual y sostenida de un punto de confianza dentro de un ecosistema de proveedores; por ello no existe una cifra oficial de "porcentaje de envíos por día" comparable a la de otros ataques de esta lista. El dato cuantitativo más cercano y verificable disponible es el de frecuencia/incidencia en brechas de seguridad: según el Data Breach Investigations Report (DBIR) 2025 de Verizon, la participación de terceros (cadena de suministro) en las violaciones de datos se duplicó, pasando de aproximadamente el 15 % en el informe anterior al 30 % de todas las brechas analizadas en 2025, sobre un total de 22 052 incidentes de seguridad analizados (Verizon, 2025; Fortra, 2025).

Qué procesos de ataque realiza

Según el marco MITRE ATT&CK (técnica T1195, "Supply Chain Compromise", con sus subtécnicas T1195.001 de dependencias, T1195.002 de software y T1195.003 de hardware), el proceso típico consta de las siguientes fases (Infosec Institute, 2025; Vectra AI, 2026):

1) Reconocimiento del ecosistema de proveedores: el atacante identifica un proveedor, biblioteca o componente ampliamente utilizado por las organizaciones objetivo.

2) Compromiso inicial del eslabón débil: se vulnera al proveedor mediante robo de credenciales, explotación de vulnerabilidades en su infraestructura de compilación (build pipeline) o mediante técnicas de "confusión de dependencias" (dependency confusion).

3) Inserción de código malicioso: se incrusta una puerta trasera o payload dentro del producto legítimo, a menudo firmado digitalmente con certificados válidos del propio proveedor para evadir la detección.

4) Distribución a través de un canal de confianza: el componente comprometido se distribuye mediante el mecanismo normal de actualización o descarga del producto, alcanzando a todos los clientes del proveedor.

5) Ejecución y acceso inicial en las víctimas finales: al instalarse la actualización, el código malicioso se activa dentro de la red de cada organización cliente.

6) Movimiento lateral, persistencia y exfiltración o impacto: el atacante consolida su presencia dentro de las redes comprometidas y ejecuta su objetivo final (robo de datos, espionaje, despliegue de ransomware o sabotaje).

Man-in-the-Middle (MITM)

Nombre

Ataque de intermediario o Man-in-the-Middle (MITM), también denominado "ataque en el camino" (on-path attack) o, en su variante moderna orientada al robo de credenciales, "adversary-in-the-middle" (AiTM).

Por quién fue creado

El principio del ataque MITM —interceptar y alterar una comunicación entre dos partes que creen estar comunicándose directamente— es anterior a la informática. Uno de los primeros casos documentados es el llamado "complot de Babington" de 1586, en el que agentes de la reina Isabel I de Inglaterra interceptaron y modificaron la correspondencia cifrada de María, reina de Escocia, para desenmascarar una conspiración en su contra (TechRepublic, 2023). En 1834, los hermanos François y Joseph Blanc sobornaron a operadores de la red de telégrafos de semáforos francesa (inventada por Claude Chappe) para insertar información bursátil falsa en las transmisiones oficiales, otro caso temprano de intermediación fraudulenta (NordVPN, 2026). El primer caso registrado en el ámbito de las telecomunicaciones inalámbricas ocurrió en 1903, cuando Nevil Maskelyne interceptó y alteró una demostración pública de telegrafía sin hilos del profesor John Ambrose Fleming, colaborador de Guglielmo Marconi (Heimdal Security, 2023). En la era de las redes informáticas modernas, el

concepto se formalizó durante las décadas de 1980 y 1990, lo que motivó el desarrollo de protocolos de cifrado como SSL/TLS como contramedida (Lumifi Cybersecurity, 2025).

Cuál es el objetivo

El objetivo es que un atacante se posicione de forma encubierta entre dos partes que se comunican (por ejemplo, un usuario y un sitio web, o un usuario y una red Wi-Fi), de modo que ambas sigan creyendo que se comunican directamente entre sí, mientras el atacante intercepta, lee, modifica o inyecta información en el tráfico con fines de espionaje, robo de credenciales, secuestro de sesión o fraude financiero (SentinelOne, 2025).

Descripción

Un ataque MITM se produce cuando un actor malicioso logra insertarse en el canal de comunicación entre dos partes, ya sea de forma pasiva (solo escucha) o activa (modifica los datos en tránsito).

Por qué medio se produce (con ejemplos)

Se produce principalmente a través de: puntos de acceso Wi-Fi falsos (rogue access points) que imitan redes de confianza, envenenamiento de caché ARP (ARP spoofing) en redes locales, envenenamiento de DNS, remoción o degradación forzada de cifrado (SSL stripping) y suplantación de certificados digitales. Casos reales documentados incluyen: la "Operación Socialist", en la que la agencia británica GCHQ, mediante la técnica "Quantum Insert", vulneró la infraestructura de la operadora belga Belgacom entre 2010 y 2013 para interceptar tráfico de roaming móvil (Wikipedia, s.f.-b); y la filtración de Edward Snowden en 2013, que reveló que la Agencia de Seguridad Nacional de Estados Unidos (NSA) falsificó certificados SSL para hacerse pasar por Google y así interceptar las búsquedas de sus usuarios (Lumifi Cybersecurity, 2025).

Cuál es el porcentaje de envíos por día

Este tipo de ataque tampoco se mide en "envíos diarios" por su propia naturaleza (no es una campaña de mensajería masiva, sino una técnica de posicionamiento en la red), por lo que no existe una cifra oficial de incidencia diaria exacta. Las aproximaciones disponibles en la industria, que deben tomarse con cautela por provenir de reportes comerciales y no de un organismo único como CISA o ENISA, varían de forma considerable: algunas fuentes citan que los ataques MITM son responsables de aproximadamente el 19 % de los ciberataques exitosos (JumpCloud, 2025; Splunk, 2025), mientras que otra estimación indica que hasta un 35 % de la actividad de explotación de vulnerabilidades involucra técnicas de intermediario (StrongDM, 2025). Dada la disparidad entre fuentes, se recomienda tomar el rango 19 %-35 % como aproximación referencial y no como una cifra exacta.

Qué procesos de ataque realiza

El proceso técnico de un ataque MITM consta de las siguientes fases (SentinelOne, 2025; Bitdefender, 2026):

1) Posicionamiento (interceptación): el atacante gana un punto de apoyo en la red mediante la creación de un punto de acceso Wi-Fi falso, el envenenamiento de la tabla ARP de la red local o la manipulación de respuestas DNS.

2) Interceptación del tráfico: una vez posicionado entre la víctima y el destino legítimo, el atacante captura los paquetes de datos que circulan entre ambos.

3) Descifrado o remoción de cifrado: si el tráfico está cifrado, el atacante intenta degradarlo (SSL stripping) o suplantar certificados digitales para poder leer su contenido en texto plano.

4) Lectura, modificación o inyección de datos: el atacante puede simplemente observar la información (contraseñas, cookies de sesión, datos financieros) o alterar activamente el contenido antes de reenviarlo a su destino.

5) Retransmisión (relay): el atacante reenvía la comunicación —original o modificada— a la parte receptora para que ninguna de las dos víctimas note la interrupción.

6) Explotación de la información obtenida: uso de las credenciales, tokens de sesión o datos capturados para acceder a cuentas, realizar fraude financiero o pivotar hacia otros sistemas de la red.

XSS (Cross-Site Scripting)

Nombre

Cross-Site Scripting, conocido por sus siglas XSS (el acrónimo "CSS" no se utiliza para evitar confusión con las hojas de estilo en cascada).

Por quién fue creado

Las primeras instancias documentadas de esta vulnerabilidad datan de finales de 1999, cuando ingenieros de seguridad de Microsoft detectaron un patrón de inyección de etiquetas de script en páginas HTML no relacionadas entre sí (FOSSA, 2021). El nombre "Cross-Site Scripting" fue acuñado oficialmente por el equipo de seguridad de Microsoft en enero del año 2000, en conjunto con el CERT (Equipo de Respuesta a Emergencias Informáticas), que publicó el aviso CERT Advisory CA-2000-02, titulado "Malicious HTML Tags Embedded in Client Web Requests" (Wikipedia, s.f.-c; Oberfelder, 2017). Años más tarde, en 2005, el investigador Amit Klein identificó y describió formalmente una tercera variante de este ataque, conocida como XSS basado en DOM (DOM-Based XSS) (OWASP, s.f.).

Cuál es el objetivo

El objetivo del atacante es inyectar código de script (generalmente JavaScript) malicioso dentro de una página web legítima, de forma que dicho código se ejecute en el navegador de otros usuarios que visiten la página, permitiendo robar cookies de sesión, secuestrar cuentas de usuario, redirigir a sitios

fraudulentos, registrar pulsaciones de teclado (keylogging), desfigurar el sitio web o propagarse de forma autónoma como un gusano informático (OWASP, s.f.).

Descripción

El XSS es una vulnerabilidad de inyección de código que se clasifica principalmente en tres tipos: XSS reflejado (el script viaja como parte de una solicitud HTTP y se refleja de inmediato en la respuesta del servidor sin ser sanitizado), XSS almacenado o persistente (el script queda guardado en la base de datos del sitio, por ejemplo en un campo de comentarios, y se ejecuta cada vez que cualquier usuario visualiza esa página) y XSS basado en DOM (la vulnerabilidad reside enteramente en el código del lado del cliente, sin que el servidor participe en la inyección) (PortSwigger, s.f.; OWASP, s.f.).

Por qué medio se produce (con ejemplos)

Se produce por la falta de validación o sanitización adecuada de las entradas proporcionadas por el usuario (campos de búsqueda, formularios de comentarios, parámetros de URL) antes de que dichas entradas sean incluidas dentro del HTML de una página. Casos reales documentados incluyen: el gusano "Samy", creado por Samy Kamkar en 2005, que explotó una vulnerabilidad de XSS almacenado en el perfil "Acerca de mí" de MySpace y que, en solo 20 horas, infectó a más de un millón de perfiles, obligando a la red social a cerrar temporalmente el sitio (Wikipedia, s.f.-d); el ataque a British Airways en 2018, atribuido al grupo Magecart, que inyectó JavaScript malicioso en la página de pago de la aerolínea para robar los datos de tarjetas de crédito de 380 000 transacciones, lo que derivó en una multa de 20 millones de libras esterlinas bajo el RGPD europeo (DEV Community, 2024); y la vulneración de eBay entre 2015 y 2016, causada por una validación insuficiente en un parámetro de redirección de URL (Abaravičius, 2024).

Cuál es el porcentaje de envíos por día

El XSS no es un ataque que se envíe masivamente por correo, sino una vulnerabilidad explotada dentro de sitios web específicos, por lo que no existe un "porcentaje de envíos por día" propiamente dicho ni una fuente oficial (CISA, OWASP o similar) que reporte esa cifra exacta. La aproximación más cercana disponible es la de prevalencia: según cifras atribuidas a OWASP, el XSS representa entre el 10 % y el 15 % de las vulnerabilidades web reportadas anualmente (Abaravičius, 2024), y ha figurado en todas las ediciones de la lista OWASP Top 10 desde su creación, integrándose en 2021 dentro de la categoría más amplia de "Injection" (Huli, 2023). Otras fuentes secundarias, de menor rigor estadístico, estiman que más del 60 % de las aplicaciones web podrían ser vulnerables a este tipo de ataque y que el XSS representaría más del 30 % de los ataques dirigidos a aplicaciones web (Zenarmor, s.f.); esta última cifra debe tomarse como una aproximación de la industria y no como un dato oficial verificado.

Qué procesos de ataque realiza

El proceso de explotación de una vulnerabilidad XSS sigue, en términos generales, las siguientes fases (PortSwigger, s.f.; OWASP, s.f.):

1) Reconocimiento: el atacante identifica un punto de entrada de datos del usuario (campo de búsqueda, formulario, parámetro de URL, campo de comentarios) que no sanitiza adecuadamente la información recibida.

2) Elaboración del payload: se construye un fragmento de código JavaScript malicioso, a menudo camuflado dentro de etiquetas HTML (por ejemplo, mediante atributos de eventos como onerror u onload) para evadir filtros básicos.

3) Inyección: el payload se introduce en el sitio vulnerable, ya sea de forma reflejada (a través de un enlace manipulado enviado a la víctima), almacenada (guardándolo permanentemente en la base de datos del sitio) o mediante manipulación del DOM en el propio navegador.

4) Entrega a la víctima: en el caso del XSS reflejado, el atacante distribuye el enlace malicioso mediante correo electrónico, redes sociales o anuncios; en el XSS almacenado, basta con que la víctima visite la página afectada.

5) Ejecución en el navegador de la víctima: el navegador interpreta el script como si perteneciera legítimamente al sitio, otorgándole acceso al contexto de seguridad de dicho dominio (cookies, sesión activa, formularios).

6) Explotación: el script ejecuta acciones maliciosas como el robo de cookies de sesión, la redirección a sitios de phishing, el registro de pulsaciones de teclado o, como en el caso del gusano Samy, la autopropagación hacia nuevos perfiles o usuarios.

Spoofing

Nombre

Spoofing o suplantación de identidad digital, con variantes específicas según el protocolo o canal afectado: spoofing de correo electrónico (email spoofing), de dirección IP (IP spoofing), de protocolo de resolución de direcciones (ARP spoofing), de sistema de nombres de dominio (DNS spoofing) y de identificador de llamadas (Caller ID spoofing).

Por quién fue creado

La suplantación de identidad como técnica de engaño es anterior a la informática y se remonta a prácticas históricas de falsificación de correspondencia y firmas (Ontinue, 2023). Su origen específicamente digital se sitúa en el diseño mismo de los protocolos de la suite TCP/IP, los cuales, según explica Wikipedia (s.f.-e), no incorporan mecanismos nativos para autenticar el origen o destino real de un mensaje, dejando la puerta abierta a la falsificación de dicho origen. En el ámbito del correo electrónico, el spoofing surgió como una extensión de las primeras técnicas de phishing, mencionadas

por primera vez en 1996, cuando atacantes crearon cuentas falsas de America Online (AOL) utilizando números de tarjeta de crédito fraudulentos para posteriormente enviar correo no deseado suplantando remitentes de confianza (Fortinet, s.f.).

Cuál es el objetivo

El objetivo del spoofing es que un atacante se identifique falsamente como otra persona, dispositivo o sistema —falsificando datos como una dirección IP, una dirección de correo, una dirección MAC o un registro DNS— con el fin de obtener una ventaja ilegítima: acceder a sistemas restringidos, evadir filtros de seguridad, engañar a la víctima para que revele información sensible, redirigir tráfico de red o servir como paso previo para ataques más elaborados, como el Man-in-the-Middle (Wikipedia, s.f.-e; Vectra AI, 2026).

Descripción

El spoofing puede ejecutarse en distintas capas de la comunicación digital, siendo las variantes más comunes el spoofing de correo electrónico (falsificación de la cabecera "De" de un mensaje), el spoofing de IP (falsificación de la dirección IP de origen de un paquete de red), el spoofing de ARP (asociación fraudulenta de una dirección MAC del atacante con la IP de un dispositivo legítimo dentro de una red local) y el spoofing de DNS o envenenamiento de caché DNS (introducción de registros falsos en un servidor de nombres de dominio para redirigir el tráfico hacia un sitio malicioso) (Imperva, 2023; Rapid7, s.f.).

Por qué medio se produce (con ejemplos)

Se produce mediante la falsificación de cabeceras de correo electrónico, el envío de mensajes ARP fraudulentos dentro de una red local, la corrupción de registros de servidores DNS o la manipulación del identificador de llamadas telefónicas. Casos reales documentados incluyen las campañas "DNSpionage" y "Sea Turtle" (2018-2019), que atacaron infraestructura DNS en Medio Oriente, el norte de África y partes de Europa mediante el secuestro de registradores y servidores de nombres para redirigir el tráfico legítimo hacia servidores controlados por los atacantes (Abnormal AI, 2026); y el uso extendido del spoofing de marca en campañas de phishing, en las que Microsoft ha sido consistentemente la marca más suplantada a nivel mundial, apareciendo en cientos de incidentes de phishing reportados por el Anti-Phishing Working Group (APWG) (BrightDefense, 2026).

Cuál es el porcentaje de envíos por día

A diferencia de los ataques anteriores, el spoofing de correo electrónico sí cuenta con estimaciones de volumen diario, ya que suele emplearse como vector de campañas masivas de phishing. Diversas fuentes de la industria (AAG IT Support, 2025; StationX, 2026) coinciden en que se envían aproximadamente 3400 millones de correos electrónicos fraudulentos o suplantados (phishing/spoofing) cada día a nivel mundial. De forma complementaria, otra estimación reciente

indica que al menos 1 de cada 99 correos electrónicos enviados globalmente corresponde a un intento de phishing, muchos de los cuales emplean marcas y dominios suplantados (sqmagazine, 2026). Debe señalarse que estas cifras provienen de reportes de proveedores de seguridad y no de un organismo regulador único, por lo que constituyen aproximaciones de la industria y no una medición oficial centralizada.

Qué procesos de ataque realiza

El proceso de un ataque de spoofing varía según su variante técnica, pero en términos generales sigue las siguientes fases (Imperva, 2023; Bitdefender, 2026; Rapid7, s.f.):

1) Selección del objetivo y de la identidad a suplantar: el atacante elige a la víctima y determina qué entidad de confianza falsificará (un banco, una marca reconocida, un dispositivo de la red local, un servidor DNS).

2) Falsificación de los datos de identidad: se manipulan las cabeceras del protocolo correspondiente —el campo "De" en un correo electrónico, la dirección IP de origen de un paquete, las respuestas del protocolo ARP o los registros de un servidor DNS— para que aparenten proceder de una fuente legítima.

3) Distribución o inyección: en el caso del correo, el mensaje falsificado se envía de forma masiva; en el caso de ARP o DNS, el atacante inyecta respuestas fraudulentas dentro del tráfico de la red o del servidor de nombres.

4) Explotación de la confianza de la víctima: la víctima (persona o sistema automatizado) acepta la comunicación como legítima, ya sea abriendo un correo, aceptando una conexión de red o resolviendo un dominio hacia la dirección falsificada.

5) Entrega del payload o redirección: el atacante consigue así entregar un enlace de phishing, un archivo malicioso, o simplemente redirigir el tráfico de red hacia un servidor bajo su control.

6) Persistencia (en spoofing de red): en el caso de ARP o DNS, el atacante debe reenviar periódicamente las respuestas falsificadas para mantener el engaño, ya que las tablas ARP y las cachés DNS legítimas tienden a autocorregirse con el tiempo.

Drive-by Download

Nombre

Ataque de descarga oculta o Drive-by Download.

Por quién fue creado

Este tipo de ataque no es atribuible a un único creador o fecha de origen exacta, sino que emergió como técnica generalizada a mediados de la década de 2000, cuando los atacantes comenzaron a explotar de forma sistemática complementos inseguros del navegador Internet Explorer, como ActiveX y los

applets de Java, para instalar malware sin necesidad de interacción del usuario (ManageEngine, s.f.). Esta técnica se profesionalizó con la aparición de los llamados "kits de explotación" (exploit kits), herramientas automatizadas que identificaban y aprovechaban vulnerabilidades del navegador o de sus complementos; entre los más conocidos e influyentes se encuentran el kit Blackhole, predominante entre 2010 y 2013, y su sucesor, el kit Angler, activo hasta mediados de la década de 2010 (Sangfor, 2024; ManageEngine, s.f.).

Cuál es el objetivo

El objetivo es instalar software malicioso (malware, spyware, ransomware o troyanos bancarios) en el dispositivo de la víctima de forma automática y sin su conocimiento ni consentimiento explícito, aprovechando vulnerabilidades no parchadas en el navegador, sus complementos (plugins) o el sistema operativo, por el simple hecho de que el usuario visite una página web comprometida o maliciosa, sin necesidad de que haga clic en ningún enlace o archivo (Kaspersky, s.f.; NordVPN, 2026).

Descripción

El drive-by download ocurre cuando el código malicioso incrustado en una página web se ejecuta automáticamente en el navegador del visitante, aprovechando fallos de seguridad para descargar e instalar malware sin que se requiera ninguna acción consciente por parte del usuario, más allá de la simple visita al sitio (NordVPN, 2026).

Por qué medio se produce (con ejemplos)

Se produce principalmente a través de tres vías: la "publicidad maliciosa" o malvertising (anuncios legítimos de una red publicitaria que son comprometidos e insertados en sitios web de buena reputación), la compra o compromiso directo de sitios web legítimos que son inyectados con scripts maliciosos, y los llamados ataques de "pozo de agua" (watering hole), en los que se compromete un sitio frecuentado por un grupo específico de usuarios (Seraphic Security, 2025). Un caso real ampliamente documentado ocurrió en 2016, cuando las redes publicitarias de sitios de alto tráfico como la BBC y The New York Times fueron comprometidas: los anuncios maliciosos redirigían de forma silenciosa a los visitantes hacia servidores que alojaban el kit de explotación Angler, el cual buscaba versiones desactualizadas de Adobe Flash e Internet Explorer para instalar ransomware y troyanos bancarios sin necesidad de ningún clic por parte del usuario (ManageEngine, s.f.). Otro caso documentado es la campaña de malware SocGholish, identificada en 2018, que se propagó a través de más de 300 sitios web comprometidos (ManageEngine, s.f.).

Cuál es el porcentaje de envíos por día

El drive-by download no se mide en "envíos" (no es un ataque de mensajería), sino en sitios web infectados o comprometidos. El dato más citado en la industria, aunque proviene de un informe de la empresa de seguridad Sophos ya con algunos años de antigüedad y sin una actualización pública

equivalente más reciente, indica que se infectan más de 30 000 sitios web nuevos cada día a nivel mundial, de los cuales aproximadamente un 80 % son sitios legítimos que fueron vulnerados (no creados por los propios atacantes), y que el drive-by download constituye la principal amenaza de malware proveniente de la web, la cual es responsable de cerca del 85 % de todo el malware detectado (Sophos, citado en SecurityWeek, 2023). Al no contar con una fuente más reciente y oficial (como CISA o ENISA) que reporte esta métrica específica de forma continua, esta cifra debe entenderse como una aproximación histórica de referencia y no como un dato actualizado al presente año.

Qué procesos de ataque realiza

Según el análisis técnico publicado por Sophos (s.f.), el proceso de un ataque de drive-by download consta de las siguientes fases:

1) Punto de entrada: el atacante compromete un sitio web legítimo (inyectando código malicioso) o coloca un anuncio malicioso dentro de una red publicitaria legítima.

2) Distribución: cuando la víctima visita el sitio comprometido, un script oculto la redirige, generalmente sin que note nada anómalo, hacia un servidor controlado por el atacante que aloja un kit de explotación.

3) Exploración de vulnerabilidades (exploit): el kit de explotación analiza de forma automatizada el navegador, el sistema operativo y los complementos instalados en el dispositivo de la víctima (por ejemplo, Adobe Flash, Java o el lector de PDF) en busca de una vulnerabilidad conocida y no corregida.

4) Entrega del payload: al encontrar una vulnerabilidad explotable, el kit descarga e instala el malware correspondiente (ransomware, troyano bancario, spyware) directamente en el dispositivo, sin requerir ninguna confirmación del usuario.

5) Ejecución e infección: el malware se ejecuta en segundo plano, a menudo estableciendo persistencia en el sistema para mantener el acceso o continuar robando datos sin ser detectado.

6) Impacto: dependiendo del payload entregado, el resultado final puede ser el cifrado de archivos (ransomware), el robo de credenciales bancarias, el reclutamiento del equipo dentro de una red de bots (botnet) o el robo silencioso de información sensible.

Phishing

Quién creo el phishing

El 2 de enero de 1996 fue la primera vez que se utilizó el término ‘phishing’ y su mención tuvo lugar en el seno del primer proveedor de Internet: America Online (AOL).

En esto consistió el primero de los ataques de phishing: se robaron contraseñas a usuarios reales de AOL y, mediante algoritmos, se crearon números aleatorios de tarjetas de crédito para abrir nuevas

cuentas en AOL. Después, usaron esas cuentas falsas para enviar mensajes de spam a los usuarios haciéndose pasar por trabajadores del propio servicio.

En dichos mensajes, se instaba a los usuarios a verificar sus cuentas, una trampa en la que la mayoría cayeron sin remedio.

Cuál es su objetivo

El objetivo principal es el robo de identidad, permitiendo a los atacantes acceder a cuentas personales o sistemas de la empresa, lo que puede provocar pérdidas financieras o daños a la reputación. El phishing explota la confianza y la urgencia humanas. A pesar de los avances en ciberseguridad, sigue siendo una amenaza, por lo que es crucial mantenerse alerta y precavido.

Descripcion

El **phishing** es una técnica de estafa digital e **ingeniería social** en la que los ciberdelincuentes se hacen pasar por una empresa, banco o entidad legítima para engañar a las personas y robar sus datos personales o bancarios.

Descripcion

Por qué medios se produce

Los ataques de phishing comienzan con un correo electrónico, una llamada telefónica, un mensaje de texto, una publicación en redes sociales o similar que parece provenir de una fuente confiable. A partir de ahí, el atacante puede tener diversos objetivos, como engañar a la víctima para que revele información de su cuenta, realice una transferencia de PayPal, descargue malware disfrazado, etc.

Cuál es el porcentaje de envios por dia

Se envían diariamente 3.400 millones de correos electrónicos de phishing; el 82,6% son generados por IA (Keepnet/VIPRE).

Qué procesos de ataque realiza

Quienes realizan phishing usan diversas técnicas para hacer que sus ataques parezcan más creíbles para sus objetivos y cumplir sus metas. Entre algunas técnicas habituales de phishing, se incluyen:

Ingeniería Social: la ingeniería social utiliza la psicología para manipular a los objetivos de los ataques de phishing. Una persona que hace phishing puede recurrir al engaño, la coerción, la coima u otras técnicas para lograr su objetivo.

Typosquatting: quienes realizan phishing pueden usar dominios y URL que se parecen mucho a los de un dominio legítimo y confiable. Si el objetivo no está prestando suficiente atención, puede creer que el enlace es legítimo.

Suplantación de identidad por correo electrónico: un correo electrónico falsificado está diseñado para que el nombre que se muestra pertenezca a alguien en quien confíe el destinatario. El campo del

remitente en un correo electrónico solo tiene datos y está bajo el control del remitente. Quienes realizan phishing utilizan este hecho para hacer que los correos electrónicos parezcan provenir de cuentas de confianza.

Acortamiento de URL: los acortadores de enlaces como bit.ly ocultan el destino de una URL. Los atacantes usan esto para engañar a un objetivo con el fin de que haga clic en un enlace a una página de phishing.

Redireccionamientos maliciosos: los redireccionamientos están diseñados para enviar un navegador a otra página si la URL original no está disponible, es incorrecta o está desactualizada. Los redireccionamientos maliciosos se pueden usar para enviar a un usuario a una página de phishing en lugar de una legítima.

Enlaces ocultos: los enlaces pueden ocultarse en texto o imágenes aparentemente inofensivos. Si un usuario hace clic accidentalmente en el enlace oculto, se lo envía a una página de phishing.

Spear phishing

Quién creo el spear phishing

El phishing, técnica de ingeniería social usada como acceso inicial desde mediados de los años 90, no es más que una herramienta más para engañar a la víctima y obtener información confidencial disfrazando dicho correo con mensajes engañosos que parecen cercanos a la víctima y difíciles (en la mayoría de los casos) de distinguir a simple vista del correo al que intentan emular los atacantes.

De la mano de esta técnica, llegamos al Spear-Phishing, el cual aplica diferentes subtécnicas (T1566.001, T1566.002, T1566.003), el cual, aprovechando el correo fraudulento, trata de que la víctima acceda a un link, a un documento adjunto, etc.

Cuál es su objetivo

Aunque el objetivo de los ataques de spear phishing suele ser robar información como credenciales de inicio de sesión o datos de tarjetas de crédito, algunos están diseñados para infectar dispositivos con malware. A menudo, quienes crean estafas de spear phishing son hackers y hacktivistas patrocinados por gobiernos. Sin embargo, ciberdelincuentes particulares también llevan a cabo estos ataques con la intención de robar identidades o cometer fraudes financieros, manipular las cotizaciones bursátiles, espiar o robar datos confidenciales para revenderlos a gobiernos, empresas privadas u otras personas interesadas.

Descripcion

El spear phishing hace referencia a los ataques de suplantación de identidad (phishing) selectivos.

Por qué medios se produce

Utilizando su investigación, los ciberdelincuentes crean mensajes de phishing dirigidos que parecen altamente creíbles. La clave está en que estos mensajes contienen detalles personales y profesionales que la víctima cree erróneamente que solo una fuente confiable podría conocer.

Por ejemplo, imaginemos que Jack es gerente de cuentas por pagar en ABC Industries. Al revisar el perfil público de Jack en LinkedIn, un atacante podría encontrar su cargo, responsabilidades, dirección de correo electrónico de la empresa, nombre y cargo de su jefe, y nombres y cargos de sus socios comerciales.

El hacker puede usar estos datos para enviar un correo electrónico creíble haciéndose pasar por el jefe de Jack:

Hola Jack,

Sé que gestionas las facturas de XYZ Systems. Me acaban de informar que están actualizando su sistema de pagos y que todos los pagos futuros deben realizarse a una nueva cuenta bancaria. Aquí tienes su última factura con los datos de la nueva cuenta. ¿Puedes enviar el pago hoy mismo?

La factura adjunta es falsa y la supuesta "nueva cuenta bancaria" pertenece al estafador. Jack entrega el dinero directamente al atacante al realizar el pago.

Un correo electrónico de phishing suele incluir elementos visuales que le dan mayor credibilidad a la estafa. Por ejemplo, el atacante podría usar una dirección de correo electrónico falsificada que muestre el nombre del jefe de Jack, pero que oculte la dirección fraudulenta que utilizó.

El atacante también podría incluir en copia (CC) el correo electrónico de un compañero de trabajo falsificado e insertar una firma que muestre el logotipo de la empresa ABC Industries.

Un estafador hábil incluso podría piratear la cuenta de correo electrónico del jefe de Jack y enviar el mensaje desde allí, sin darle a Jack ningún motivo para sospechar.

Algunos estafadores llevan a cabo campañas híbridas de spear phishing que combinan correos electrónicos de phishing con mensajes de texto (denominados "phishing por SMS" o " smishing ") o llamadas telefónicas (denominadas "phishing por voz" o "vishing").

Por ejemplo, en lugar de adjuntar una factura falsa, el correo electrónico podría indicarle a Jack que llame al departamento de cuentas por pagar de XYZ Systems a un número de teléfono controlado secretamente por un estafador.

Debido a que utilizan múltiples modos de comunicación, los ataques de spear phishing híbridos suelen ser incluso más efectivos que los ataques de spear phishing estándar.

Cuál es el porcentaje de envios por dia

0.1% de todos los emails de phishing son spear phishing. Sin embargo, esa fraccion minuscula causa el 66% de todas las brechas de seguridad corporativas. La diferencia entre un email de phishing generico y uno de spear phishing es la misma que entre un disparo a ciegas y un francotirador: precision letal. En

2025, con la IA generativa permitiendo personalizar ataques a escala industrial, el phishing dirigido en Espana aumento un 466% según ESET, y el 88% de las organizaciones sufrieron al menos un intento de spear phishing durante el ano. INCIBE registro un incremento del 25% en fraudes por phishing y smishing, concentrados en banca, logistica y sanidad.

Qué procesos de ataque realiza

Son cinco los pasos que se realizan para preparar un ataque de spear phishing. Los siguientes son estos pasos:

Definir los objetivos del ataque.

Seleccionar los objetivos por medio de una investigación preliminar.

Identificar una lista de objetivos e investigarlos en detalle.

Redactar el correo electrónico de spear phishing usando la información recopilada y técnicas de ingeniería social.

Estos ataques selectivos funcionan porque los correos electrónicos de spear phishing crean una sensación de familiaridad respecto de la vida del destinatario. Los atacantes dedican mucho tiempo y esfuerzo a obtener todos los detalles posibles sobre el trabajo, la vida, las amistades y la familia del destinatario. Al rastrear Internet y los perfiles de las redes sociales en plataformas como Facebook y LinkedIn, estos atacantes (denominados phishers) pueden encontrar datos como direcciones de correo electrónico y números telefónicos, una red de amistades, familiares y contactos de negocios, lugares frecuentados, e información como la empresa en la que trabaja y su cargo, los sitios en línea donde realiza compras, los servicios bancarios que utiliza, etc. Con toda esta información, los atacantes pueden elaborar perfiles exhaustivos de sus potenciales objetivos y, mediante técnicas de ingeniería social, redactar correos electrónicos personalizados, que parecen legítimos porque proceden de personas o empresas con las que suele interactuar y que contienen información que podría ser auténtica.

Dos

Descripcion

Uno de los primeros ataques maliciosos fue hecho por MafiaBoy, quien perpetró un ataque DDos con el mismo nombre, un ataque a la universidad de Minnesota con 114 ordenadores infectados con un código malicioso llamado Trin00

Aunque el primer ataque fue uno llamado Panix, el tercer proveedor de servicios de internet más antiguo del mundo, fue el objetivo del primer ataque DoS. El 6 de septiembre de 1996, Panix fue objeto de un ataque de inundación SYN que provocó la caída de sus servicios durante varios días mientras los proveedores de hardware de red, en particular Cisco, encontraban una defensa adecuada.

Cuál es su objetivo

El objetivo principal de un ataque DoS (Denegación de Servicio) es **saturar un sistema, servidor o red** para que deje de funcionar y no esté disponible para los usuarios legítimos.

Descripcion

En seguridad informática, un ataque de denegación de servicio, llamado también ataque DoS (por sus siglas en inglés, denial of service), es un ataque a un sistema de computadoras o red que causa que un servicio o recurso sea inaccesible a los usuarios legítimos.[1] Normalmente provoca la pérdida de la conectividad con la red por el consumo del ancho de banda de la red de la víctima o sobrecarga de los recursos computacionales del sistema atacado.

Por qué medios se produce

Un ataque de denegación de servicio (DoS) se produce mediante la saturación de los recursos de un sistema o la interrupción de sus conexiones de red utilizando un único equipo o script.Medios y técnicas principalesInundación de tráfico (Flooding): Se envían volúmenes masivos de datos, paquetes o solicitudes (como peticiones HTTP o ICMP) que rebasan la capacidad de procesamiento o el ancho de banda del servidor objetivo.Herramientas de ataque: Se emplean scripts especializados o software específico (por ejemplo, herramientas de estrés o generadores de tráfico) operados desde un equipo individual para bombardear la red.Agotamiento de recursos y conexiones (Ataques lentos): Se abren múltiples conexiones legítimas aparentes (como en los métodos Slowloris o RUDY) manteniendo las sesiones bloqueadas y consumiendo la memoria o los hilos disponibles del servidor web sin necesidad de un volumen extremo de datos.Explotación de vulnerabilidades: Se envían paquetes deformados o manipulados (como fallos en el manejo de protocolos de red tipo TCP o desbordamientos) que provocan errores graves, reinicios o caídas directas del núcleo del sistema operativo (pánico del kernel).

Cuál es el porcentaje de envios por dia

A nivel mundial, se registran aproximadamente entre 44,000 y 128,000 ataques de denegación de servicio (DoS/DDoS) por día. El comportamiento y la distribución de estos envíos maliciosos a lo largo de la semana varían de forma constante según los reportes globales de firmas de ciberseguridad como Cloudflare y Astra Security.

Qué procesos de ataque realiza

Un ataque de denegación de servicio impide el uso legítimo de los usuarios al usar un servicio de red. El ataque se puede dar de muchas formas. Pero todas tienen algo en común: utilizan la familia de protocolos TCP/IP para conseguir su propósito.

Un ataque DoS puede ser perpetrado de varias formas. Aunque básicamente consisten en:

Consumo de recursos computacionales, tales como ancho de banda, espacio de disco, o tiempo de procesador.

Alteración de información de configuración, tales como información de rutas de encaminamiento.

Alteración de información de estado, tales como interrupción de sesiones TCP (TCP reset).

Interrupción de componentes físicos de red.

Obstrucción de medios de comunicación entre usuarios de un servicio y la víctima, de manera que ya no puedan comunicarse adecuadamente.

DDos

Quién creo el DDos

El primer ataque de denegación de servicio (DoS) ocurrió en 1974, obra de David Dennis, un estudiante de 13 años de la escuela secundaria University High School, ubicada frente al Laboratorio de Investigación de Educación Basada en Computadoras (CERL) de la Universidad de Illinois Urbana-Champaign. Recientemente, David descubrió un nuevo comando que podía ejecutarse en las terminales PLATO del CERL. PLATO fue uno de los primeros sistemas computarizados de aprendizaje compartido y precursor de muchos sistemas informáticos multiusuario posteriores. El comando, llamado "external" o "ext", permitía la interacción con dispositivos externos conectados a las terminales. Sin embargo, al ejecutarse en una terminal sin dispositivos externos conectados, provocaba que la terminal se bloqueara, requiriendo apagarla y volver a encenderla para recuperar su funcionamiento.

Cuál es su objetivo

El objetivo principal de un ataque DDoS (Denegación de Servicio Distribuido) es saturar y colapsar un servidor, sitio web o red con tráfico falso para que deje de funcionar.

Metas principales del ataque:

Bloquear el acceso: Impedir que los usuarios reales o legítimos entren a una página web o usen un servicio en línea.

Agotar recursos: Consumir por completo la capacidad de procesamiento, la memoria y el ancho de banda del objetivo.

Causar pérdidas económicas: Paralizar la actividad de empresas, tiendas virtuales o bancos, generando costos por cada minuto de inactividad.

Actuar como distracción: Ocultar de manera intencional otro ataque simultáneo, como el robo de datos o la infiltración en los sistemi-as.

Descripcion

Un ataque de denegación de servicio distribuido (DDoS), también conocido como ataque de red distribuido, es un tipo de ciberataque cuyo objetivo es interrumpir o inhabilitar el tráfico normal hacia un servidor, servicio o red. En un ataque DDoS, el atacante envía a un sistema objetivo o a sistemas cercanos una avalancha de tráfico de internet. Dado que el sistema objetivo no espera este aumento repentino de tráfico, no puede procesarlo con la suficiente rapidez para evitar que se ralentice o se detenga el tráfico normal.

Por qué medios se produce

A pesar de la potencia de los ataques DDoS, puede resultar difícil identificarlos, ya que muchos de sus efectos son similares a los que se producen durante el funcionamiento normal. El síntoma más común de un ataque DDoS es la lentitud o la indisponibilidad del servidor, el servicio o la red.

Los indicadores que identifican un ataque DDoS varían según el tipo. Estas señales incluyen:

Patrones de tráfico anormales (por ejemplo, picos en horas inusuales)
Caída de la conexión a internet
Grandes cantidades de tráfico originadas desde una única dirección IP o rango de IP.
Aumento repentino de solicitudes a una sola página o punto final que no se puede explicar.
Tráfico procedente de usuarios que comparten características (por ejemplo, tipo de dispositivo, geolocalización o tipo de navegador web).
Contenido inusual en los correos electrónicos (por ejemplo, contenido multimedia) o spam excesivo.
Los sitios web dejan de estar disponibles para su visualización.
Si existe la sospecha de un ataque DDoS, los equipos de TI pueden:

Compruebe si los usuarios han recibido un error 503 (servicio no disponible).
Revise los registros de acceso para buscar indicios de un ataque.
Prueba la velocidad del sitio web, comparándola con la velocidad de un sitio web de referencia.
Intenta cargar otros sitios web y comprueba si se cargan a una velocidad normal.

Cuál es el porcentaje de envios por dia

A nivel global, se registran aproximadamente entre 44,000 y 130,000 ataques DDoS por día. Solo en la red de Cloudflare, los ataques mitigados alcanzaron un promedio de 129,000 incidentes diarios debido al masivo incremento de redes de bots y ataques automatizados.

Qué procesos de ataque realiza

Existen muchos tipos de ataques DDoS. A continuación, se muestran varios ejemplos que ilustran los diferentes enfoques.

Ataques DDoS en la capa de aplicación

Los ataques DDoS de capa 7, comúnmente conocidos como ataques DDoS, tienen como objetivo el software que presta un servicio, como el que se utiliza para generar páginas web en respuesta a solicitudes HTTP y cualquier otra aplicación basada en la nube. Este tipo de ataque DDoS es frecuente porque la capa de aplicación requiere menos ancho de banda para ejecutarse correctamente.

Ataques DDoS de protocolo

Los ataques DDoS basados en protocolos explotan vulnerabilidades en las capas 3 (red) y 4 (transporte) del modelo OSI (Interconexión de Sistemas Abiertos). Un ataque de inundación SYN es un ejemplo de ataque DDoS basado en protocolos. Este ataque inicia una conexión con el objetivo, pero no la completa. El objetivo debe consumir recursos esperando la avalancha de conexiones incompletas, lo que le impide responder al tráfico legítimo.

Ataques DDoS basados en volumen o volumétricos

Relativamente poco comunes (según se informa, menos del 1 % de los ataques DDoS se basan en el volumen), los ataques DDoS volumétricos saturan el ancho de banda entre el objetivo e internet mediante el envío masivo de tráfico de red. Un ejemplo de ataque DDoS volumétrico es la amplificación del sistema de nombres de dominio (DNS), donde un atacante falsifica la dirección del objetivo y envía una avalancha de solicitudes falsas de búsqueda de nombres DNS a servidores DNS abiertos.

5. ¿Qué países tienen más ataques de ransomware?

La distribución del ransomware a nivel mundial no es aleatoria; las bandas criminales, que hoy operan mayoritariamente bajo el modelo de Ransomware-as-a-Service (RaaS), dirigen sus ataques a geografías específicas basándose en la rentabilidad, la infraestructura digital y la capacidad de pago de las víctimas.

Estados Unidos como el objetivo principal Todos los informes de inteligencia convergen en que Estados Unidos es, por un margen muy amplio, el país más atacado del mundo. Según el informe de inteligencia de amenazas Ransomware & Extortion Activity de la firma Analyst1 (2026), Estados Unidos concentró casi el 50% de todas las reclamaciones de ataques de ransomware publicadas en sitios de filtración de datos (Data Leak Sites o DLS) en 2025 (3,936 de un total de 7,819 incidentes globales verificados). Esto es coherente con años anteriores, habiendo representado el 51% en 2024 y el 41% en 2023. El alto volumen se debe a su vasta superficie de ataque corporativa, alta concentración de infraestructuras críticas y normativas que exigen transparencia en el reporte de brechas.

El Top 10 Global (2024 - 2025) De acuerdo con las métricas consolidadas por CloudSEK (2026), Analyst1 (2026) y la firma de TI AAG, los 10 países más atacados por organizaciones de ransomware son:

1. Estados Unidos (concentrando aprox. 47% - 50% de la cuota global).
2. Reino Unido (Altamente atacado en los sectores de telecomunicaciones, finanzas y gobierno local).
3. Canadá (Fuertemente golpeado en los sectores de salud pública y educación).
4. Alemania (Objetivo primario en Europa por su potente industria manufacturera, automotriz y de ingeniería).
5. Italia
6. Francia
7. España
8. Brasil (El país latinoamericano con mayor cantidad de ataques, representando cerca del 6% global de incidentes contra empresas).
9. Australia (Ataques enfocados en plataformas gubernamentales y de identidad digital).

10. India (País que experimenta el crecimiento más veloz en volumen de ataques debido a su rápida digitalización financiera).

La correlación con el PIB Existe una regla casi estricta documentada por S2W Lab Threat Intelligence en su reporte de la segunda mitad de 2025: los 10 países con mayor número de víctimas de ransomware se encuentran simultáneamente dentro del Top 15 mundial por Producto Interno Bruto (PIB). Esto demuestra que los grupos de ataque utilizan tácticas de "Big Game Hunting" (Caza Mayor), ignorando en su mayoría a naciones de bajos ingresos para concentrarse geográficamente en regiones (Europa Occidental y Norteamérica) donde las corporaciones y municipios tienen los fondos suficientes para pagar rescates millonarios en criptomonedas.

6. ¿Cuáles son sus pérdidas?

Nota sobre la disponibilidad de datos: Determinar una cifra única y exacta del costo "total global" del ransomware es imposible debido al inmenso subregistro. Como advierten la Agencia de Ciberseguridad de la Unión Europea (ENISA, 2025) y el FBI en su portal IC3, muchas organizaciones deciden no hacer públicos sus incidentes por temor a multas regulatorias o daños a su reputación. Por lo tanto, para definir las pérdidas, la investigación se apoya en los costos promedio auditados por incidentes, los rastreos de pagos en blockchain y estimaciones macroeconómicas nacionales.

1. El Costo Promedio por Incidente El costo de un ataque no se limita a pagar a los cibercriminales; de hecho, el rescate suele ser solo una fracción de las pérdidas totales. Según el Cost of a Data Breach Report 2025 de IBM Security, el costo promedio global para que una empresa se recupere de una brecha generada por ransomware se situó en $5.08 millones de dólares por incidente. Estas pérdidas se desglosan en tres procesos:

- Pérdidas de negocios (Downtime y lucro cesante): En promedio representan $1.54 millones de dólares. Según datos de Statista (2026), el tiempo medio de inactividad de una empresa paralizada por ransomware es de 24 días.
- Detección, respuesta y crisis: Gastos en firmas forenses, restauración de copias de seguridad (si no fueron destruidas), negociadores de rescate y relaciones públicas, promediando $1.64 millones de dólares.
- Costos Legales: Demandas de clientes por exposición de datos y multas gubernamentales (Ej. violaciones HIPAA en el área de salud).

2. Pagos de Rescates Efectivos (Ransom Payments) En términos de dinero líquido transferido a organizaciones criminales, la firma de rastreo de blockchain Chainalysis, en su Crypto Crime Report

2025, logró confirmar que las víctimas pagaron alrededor de $813.55 millones de dólares en criptomonedas a bandas de ransomware durante 2024.

- Existe una caída respecto al pico de $1.25 mil millones en 2023. Esta reducción no se debe a la ausencia de ataques, sino a que las empresas ya no quieren pagar. Según el reporte Data Breach Investigations Report (DBIR) de Verizon (2025), el 64% de las víctimas de ransomware se negaron a pagar la extorsión (en 2022 esa cifra era solo del 50%).
- Para quienes sí pagaron, la mediana del rescate desembolsado en 2024 fue de $115,000 dólares (Verizon, 2025). Sin embargo, hay cifras astronómicas en ataques dirigidos; en 2024, se reportó el mayor pago de rescate de la historia documentada: $75 millones de dólares pagados por una sola empresa Fortune 50 (Stingrai Data / Admin by Request, 2026).

3. Impacto y Pérdidas Macroeconómicas Nacionales El impacto a escala nacional resulta devastador cuando suma miles de incidentes locales.

- En la Unión Europea, de acuerdo con Reuters y respaldado por ENISA (2025), solamente en Alemania, los daños económicos derivados de ciberataques (siendo el secuestro de datos operativos por ransomware la amenaza más disruptiva) totalizaron €178.6 mil millones de euros en 2024, un enorme salto frente a los €30.4 mil millones del año previo.
- En Estados Unidos, el Internet Crime Complaint Center (IC3) del FBI recibió reportes de cibercrímenes globales en 2024 con pérdidas que superaron los $16.6 mil millones de dólares.

REFERENCIAS BIBLIOGRAFICAS

Intel 471. (2023). Vulnerabilities year-in-review: 2023. https://www.intel471.com (Respalda tus estadísticas de incidencia).

OWASP Foundation. (s. f.-a). Cross site request forgery (CSRF). https://owasp.org (Referencia base para la definición y los datos del Top 10).

SecLists.org. (s. f.). Full disclosure: [ISecAuditors security advisories] CSRF vulnerability in GMail service. https://seclists.org (Documenta tu ejemplo real de Gmail).

InternetNews. (s. f.). Black Hat: Netflix CSRF vulnerability. https://www.internetnews.com (Documenta tu ejemplo real de Netflix).

Verizon. (2025). 2025 Data Breach Investigations Report. https://www.verizon.com (Respalda tus estadísticas principales sobre el 68% de brechas por factor humano).

Verizon. (2026). 2026 Data Breach Investigations Report (DBIR). https://www.verizon.com (Respalda la continuidad estadística del 60% en incidentes recientes).

Mitnick Security. (s. f.). The 2020 Twitter Bitcoin scam: How it happened and key lessons from whitehat hacker Kevin Mitnick. https://www.mitnicksecurity.com (Cubre tanto la figura de Kevin Mitnick como el ejemplo principal del ataque a Twitter en 2020).

Kaspersky. (s. f.-b). Kaspersky reports nearly 900 million phishing attempts in 2024 as cyber threats increase. https://www.kaspersky.com (Respalda tus cifras de distribución e infección).

Today In Infosec [@TodayInInfosec]. (1983/s. f.). 1983: Stony Brook student Perry Kivolowitz published Unix keylogger code to 2 newsgroups... X. https://x.com (Respalda el dato histórico exacto de la creación del primer keylogger de software).

SpyCloud. (s. f.). SpyCloud Labs insights: Infostealer & keylogger trends. https://spycloud.com (Da contexto técnico moderno sobre cómo los keyloggers ahora operan junto con los infostealers).

BeyondTrust. (2025, 15 de abril). 12th annual edition of the BeyondTrust Microsoft Vulnerabilities Report reveals record-breaking year for Microsoft vulnerabilities. https://www.beyondtrust.com/press/2025-beyondtrust-microsoft-vulnerabilities-report (Fuente primordial para tu dato de que el 40% de las vulnerabilidades son de este tipo).

Red Hat. (s.f.). Understanding and mitigating the Dirty Cow vulnerability. https://www.redhat.com/en/blog/understanding-and-mitigating-dirty-cow-vulnerability (Respalda el caso real de Dirty COW).

Sysdig. (2026, 1 de abril). Detecting and mitigating CVE-2021-4034: "Pwnkit" local privilege escalation. https://www.sysdig.com/blog/detecting-mitigating-cve-2021-4034-sysdig (Respalda el caso real de PwnKit).

U.S. Cybersecurity and Infrastructure Security Agency [CISA]. (s.f.). Stuxnet malware mitigation (Update B). https://www.cisa.gov/news-events/ics-advisories/icsa-10-238-01b (Referencia oficial para el ejemplo de Stuxnet).

Sonatype. (2024). 2024 State of the Software Supply Chain: Executive summary. https://www.sonatype.com/state-of-the-software-supply-chain/2024/introduction (La fuente más importante de tu texto para los porcentajes y volumen de paquetes maliciosos).

TradingView / Reuters. (2025, 8 de julio). Malware targeting developers reaches 845K packages according to Sonatype Open Source Malware Index. https://tr.tradingview.com/news/reuters.com... (Respalda tu actualización de datos del índice Sonatype para 2025).

MITRE ATT&CK. (s.f.). SolarWinds compromise, Campaign C0024. https://attack.mitre.org/campaigns/C0024/ (Documenta tu caso principal de SolarWinds / SUNBURST).

IEEE Xplore. (s.f.). Reflections on trusting trust after 40 years. https://ieeexplore.ieee.org/document/11208472/ (Soporta la historia teórica de Ken Thompson).

CISA. (2023). Understanding ransomware threat actors: LockBit (AA23-165A). Cybersecurity and Infrastructure Security Agency. https://www.cisa.gov/news-events/cybersecurity-advisories/aa23-165a (Documenta las fases técnicas y operativas del ataque).

Flashpoint. (2026). The seven phases of a ransomware attack: A step-by-step breakdown of the attack lifecycle. https://flashpoint.io/blog/the-anatomy-of-a-ransomware-attack/ (Respalda detalladamente el ciclo de vida del ataque en 7 pasos).

NCC Group. (2026). NCC Group data reveals 2025 was a record year for global ransomware. https://www.nccgroup.com/newsroom/ncc-group-annual-threat-monitor-review-of-2025/ (Fuente principal de tu estadística de 7 874 ataques anuales y ejemplos recientes).

Verizon. (2025). 2025 Data Breach Investigations Report. https://www.verizon.com/business/resources/reports/2025-dbir-data-breach-investigations-report.pdf (Sostiene el dato crítico de que el 44 % de las brechas involucran ransomware).

Kaspersky. (2020). The great migration of cyberthreats: Attacks on remote desktop protocols grew by 242% - reaching 3.3 billion - in 2020. https://www.kaspersky.com/about/press-releases/... (Fundamental para tu métrica de millones de ataques diarios contra el protocolo RDP).

OWASP Foundation. (s.f.-b). Brute force attack. https://owasp.org/www-community/attacks/Brute_force_attack (Referencia técnica base para la definición, objetivos y fases del ataque).

Foresite. (2025). OWASP Top 10: Injection. https://foresite.com/blog/owasp-top-10-injection (Respalda la estadística del 12 % de vulnerabilidades internas y ejemplos como el de Fortnite).

Malwarebytes. (2024). What is SQL injection - Examples & prevention. https://www.malwarebytes.com/sql-injection (Documenta la historia de origen con Jeff Forristal y la revista Phrack en 1998).

OWASP Foundation. (2021). A03 Injection – OWASP Top 10:2021. https://owasp.org/Top10/2021/A03_2021-Injection/ (Fuente primaria indispensable para la tasa de incidencia del 94 % y los detalles técnicos).

Deepstrike. (2025). Zero-day exploit statistics 2025: New baseline, new playbook. https://deepstrike.io/blog/zero-day-exploit-statistics-2025 (Cubre la estadística crítica de Mandiant sobre el 33 % de intrusiones originadas por esta vía).

Google Cloud. (2025). Look what you made us patch: 2025 zero-days in review. https://cloud.google.com/blog/topics/threat-intelligence/2025-zero-day-review (Fuente de inteligencia directa para el conteo global de 90 vulnerabilidades explotadas).

Vectra AI. (2026). Zero-day vulnerabilities: How they work and how to stop them. https://www.vectra.ai/topics/zero-day (Define de manera robusta las fases del ataque y los vectores principales).

Keeper Security. (2026). 6 most common types of password attacks. https://www.keepersecurity.com/blog/2024/01/12/types-of-password-attacks/ (Soporta tu argumento estadístico central de que el 75 % de los usuarios no usa contraseñas fuertes).

Specops Software. (2025). What is a password dictionary attack and how do password dictionary attacks exploit weak passwords. https://specopssoft.com/blog/what-is-password-dictionary-attack/ (Respalda las fases del ataque híbrido y los ejemplos reales de LinkedIn y Adobe).

TechTarget. (s.f.). What is a dictionary attack? https://www.techtarget.com/cybersecurity/definition/dictionary-attack (Contiene el análisis citado de NordPass sobre la repetición masiva de la clave "123456").

Vectra AI. (2026). Supply chain attacks: How they work and how to detect them. https://www.vectra.ai/topics/supply-chain-attack

ExtraHop. (s.f.). Supply chain attacks: Definition, examples, and history. https://www.extrahop.com/resources/attacks/supply-chain

Infosec Institute. (2025). MITRE ATT&CK: Supply chain compromise. https://www.infosecinstitute.com/resources/mitre-attck/mitre-attck-supply-chain-compromise/

Verizon. (2025). 2025 Data Breach Investigations Report. https://www.verizon.com/about/news/2025-data-breach-investigations-report

SentinelOne. (2025). What is a Man-in-the-Middle (MitM) attack? https://www.sentinelone.com/cybersecurity-101/cybersecurity/what-is-a-man-in-the-middle-mitm-attack/

Lumifi Cybersecurity. (2025). What is a Man-in-the-Middle attack (MiTM)? https://www.lumificyber.com/fundamentals/what-is-a-man-in-the-middle-attack/

Wikipedia. (s.f.-b). Operation Socialist. https://en.wikipedia.org/wiki/Operation_Socialist

Splunk. (2025). What is a MITM attack? Man in the Middle attacks, explained. https://www.splunk.com/en_us/blog/learn/man-in-the-middle-attacks.html

OWASP. (s.f.). Cross Site Scripting (XSS). https://owasp.org/www-community/attacks/xss/

PortSwigger. (s.f.). What is cross-site scripting (XSS) and how to prevent it? https://portswigger.net/web-security/cross-site-scripting

Wikipedia. (s.f.-d). Samy Kamkar. https://en.wikipedia.org/wiki/Samy_Kamkar

DEV Community. (2024). Real-world XSS case studies. https://dev.to/trixsec/part-9-cross-site-scripting-xss-series-real-world-xss-case-studies-notable-breaches-and-4d9c

Wikipedia. (s.f.-e). Spoofing attack. https://en.wikipedia.org/wiki/Spoofing_attack

Imperva. (2023). What is IP address spoofing. https://www.imperva.com/learn/ddos/ip-spoofing/

Abnormal AI. (2026). DNS cache poisoning & spoofing: How it works. https://abnormal.ai/glossary/dns-spoofing

AAG IT Support. (2025). The latest phishing statistics. https://aag-it.com/the-latest-phishing-statistics/

Kaspersky. (s.f.). What is a drive by download attack? https://www.kaspersky.com/resource-center/definitions/drive-by-download

ManageEngine. (s.f.). Drive-by downloads explained. https://www.manageengine.com/data-security/what-is/drive-by-download.html

SecurityWeek. (2023). 85 percent of malware comes from the web, 30k sites infected daily, says Sophos. https://www.securityweek.com/85-percent-malware-comes-web-30k-sites-infected-daily-says-sophos/

Sophos. (s.f.). How malware works: Anatomy of a drive-by download web attack. https://www.sophos.com/en-us/blog/how-malware-works-anatomy-of-a-drive-by-download-web-attack-infographic